

IT audit course

Bucharest, January 2025

Intro and warm up

Sessions

20.01.2025, 6pm, online session

21.01.2025, 6pm, online session

22.01.2025, 6pm, online session

Structure of each session:

- One break of 15 min
- 2 sessions of 1h 20 min

Grading

IT audit section is weighting **5 points** from the total of the course, as followings:

- **1 point for homework (1 day prior the exam 9th of February 2025)**
- **3 points the exam**
- **1 point for class activity**

Homework: Data Breach Analysis through the Lens of IT Audit

- Choose a data breach
- Research and document the incident as per specific requirements made available to you

Exam – 17 multiple choice questions, randomly selected from a bigger question pool (only one answer correct)

Class activity

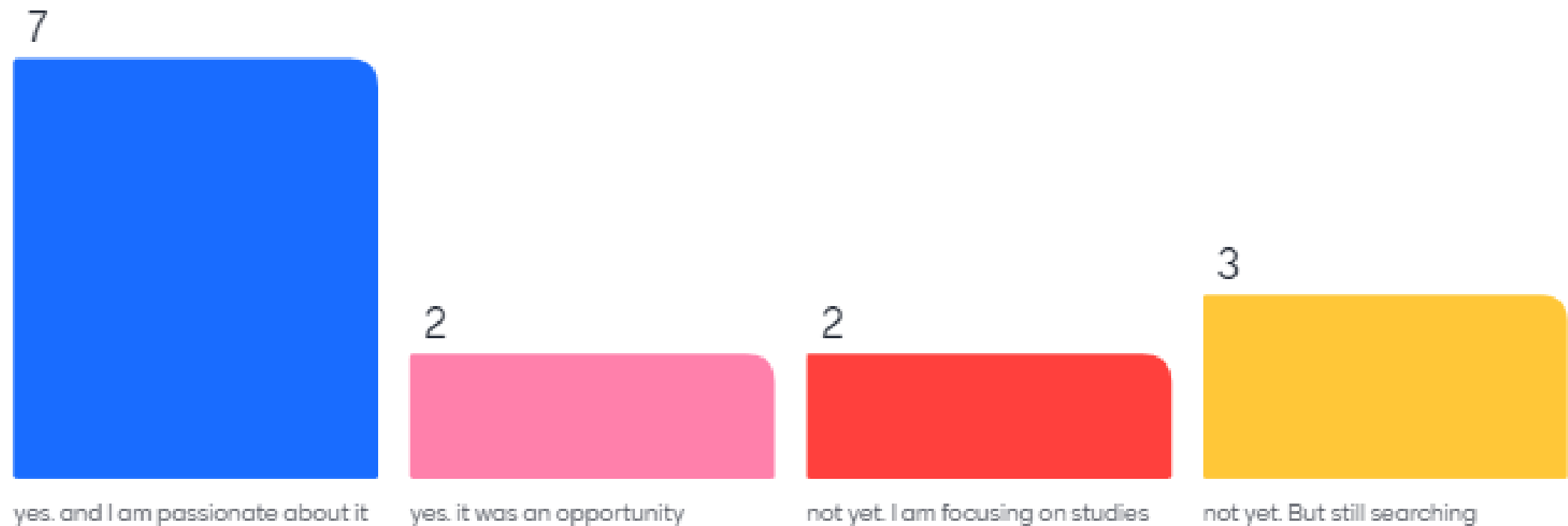
- Addressing questions during the 3 sessions
- 22nd January class session will include exercising similar exam questions and case studies where students will work in groups.

Audience and expectations

1. Do you already have a job?
 - yes. and I am passionate about it
 - yes. it was an opportunity
 - not yet. I am focusing on studies
 - not yet. But still searching
2. Area of profession/ interest
3. Your expectation on this course

<https://www.menti.com/>

Do you already have a job?



Area of profession/ interest

30 responses



Expectations

16 responses

general understanding
how audit operates
general knowledge
how security controls wor
knowledge interactive
real case studies
useless boring audit overwhelming
risk assesment
importance
real life examples
the measures needed
end product

Why

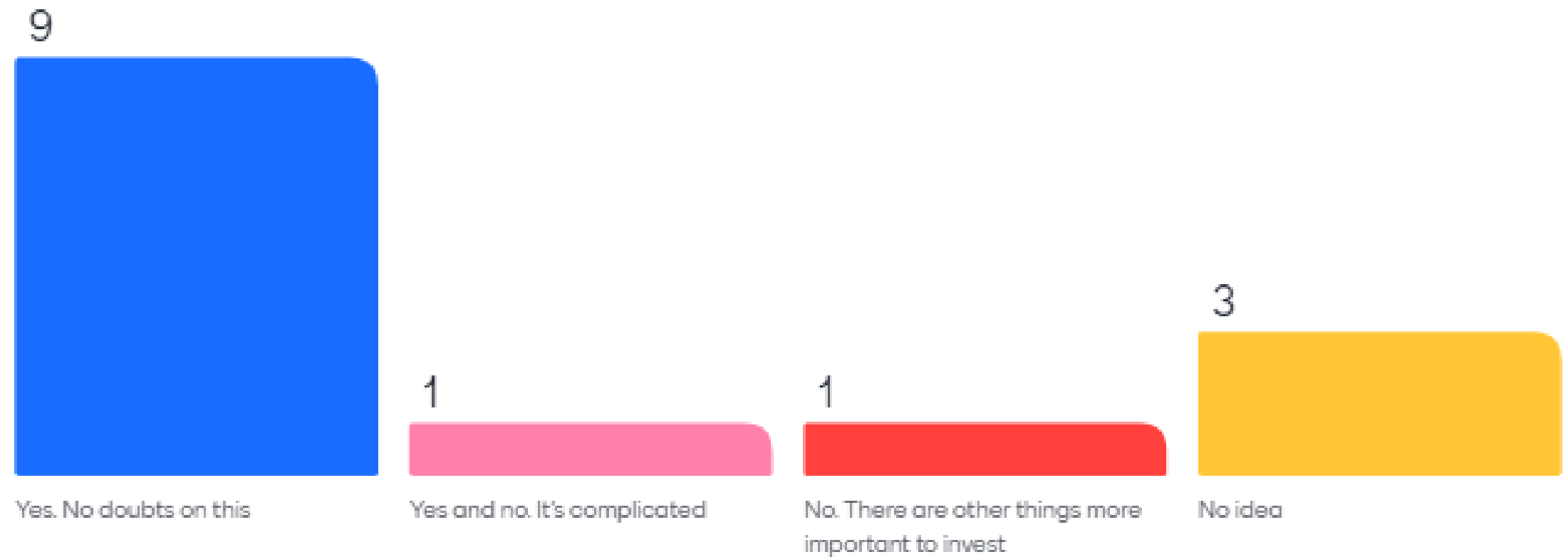
1. Do we need audit?

- Yes. No doubts on this
- Yes and no. It's complicated
- No. There are other things more important to invest
- No idea

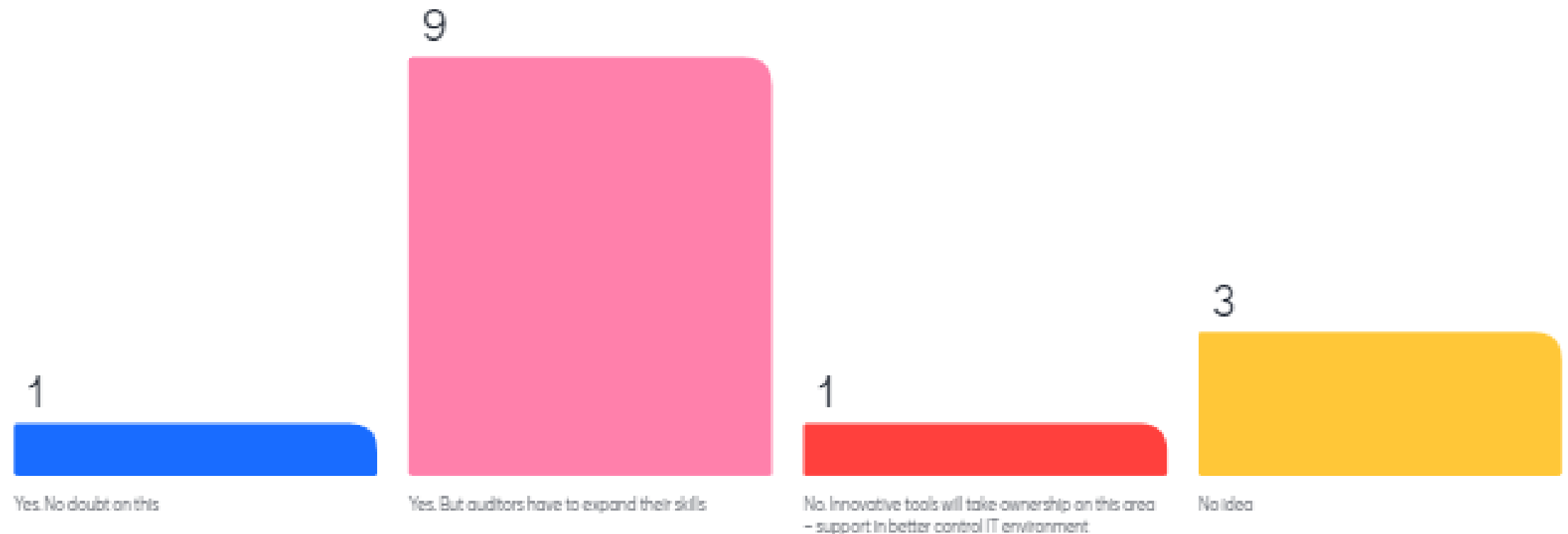
2. Is there any future for IT audit?

- Yes. No doubt on this
- Yes. But auditors have to increase their technical knowledge
- No. Innovative tools will take ownership on this area – support in better control IT environment
- No idea

Do we need audit?



Is there any future for IT audit?



FACTS

[Future of IT audit ISACA study 2019]

[2024 ISACA State of cybersecurity]



Adobe Acrobat
Document

IT Auditors Will Be Increasingly **Involved** in Major Tech Projects

IT Auditors With **Technical Skills** Will Be in High Demand

IT Auditors Are **Optimistic** About the Future

Current: Stronger demand for **technical skills** (64%)

Next short-term (1-2 years):

Auditing becoming INCREASINGLY **automated** (30%)

INCREASED need for **data scientists** on the IT audit team (28%)

Next medium term (3-5 years):

Increased reliance on **artificial intelligence (AI)**-assisted monitoring and analytics (33%)

Full **integration** of IT audit into other business areas (24%)

Embracing the Future of Auditing

The audit of tomorrow will be very different from the audit of today. Advanced technologies are enhancing audit quality and efficiency as we speak.

However, alongside these opportunities come challenges, such as a new league of cyber risks and the opacity of black boxes relating to Artificial Intelligence. At the same time, stakeholders have higher expectations of the auditor's work. Expectations that reach beyond the traditional financial domain.

Increasing Importance of Cybersecurity Audits

As cyber threats continue to escalate in frequency and sophistication, the importance of cybersecurity audits has never been more pronounced. Cybersecurity audits are designed to evaluate the effectiveness of an organization's security measures, ensuring that they can adequately protect against data breaches, malware, ransomware, and other cyber threats. The growing dependence on digital infrastructure makes robust cybersecurity audits a critical component of an organization's risk management strategy.

One of the primary drivers behind the heightened focus on cybersecurity audits is the evolving cyber threat landscape. Cybercriminals employ increasingly advanced tactics, such as spear-phishing, zero-day exploits, and advanced persistent threats (APTs), to infiltrate corporate networks. These sophisticated attacks can cause significant financial loss, reputational damage, and operational disruption. Therefore, regular and thorough cybersecurity audits are essential to identify vulnerabilities and implement necessary controls to mitigate these risks.

The Changing Audit Landscape

In 2024, auditors are facing not only more sophisticated regulatory environments, but also the growing influence of technologies such as artificial intelligence (AI), machine learning, blockchain, and robotic process automation (RPA). On top of that, issues like cybersecurity and environmental, social, and governance (ESG) concerns are no longer peripheral—they are central to how businesses operate and are scrutinised. This convergence of factors means auditors must continually adapt and enhance their technical and soft skills.

The board imperative to raise expectations

As boards are recognizing a paradigm shift wherein IA takes on a strategic role, they expect IT not just to keep pace, but also to think critically about IT audit risks.

Increasingly, boards are shifting their focus to understand how technology can also be leveraged offensively to create new opportunities, business models, and revenue.

Furthermore, they are trying to understand the new kinds of technology risks, which touch nearly every aspect of the business:

- Not executing a new strategy because of IT issues
- Failing to have the technology infrastructure needed to deliver a world-class customer experience or to support an M&A growth strategy
- Inability to enter a new market due to technological deficiencies



Cost of a Data Breach 2024 Trends

According to IBM's annual Cost of a Data Breach Report, the staggering financial impact of data breaches reached a global average of **\$4.88 million!**



Level up your cyber response training

75% of the increase in average breach costs in this year's study was due to the cost of lost business and post-breach response activities. The lesson: investing in post-breach response preparedness can help dramatically lower breach costs.

Know your information landscape

40% of data breaches involved data stored across multiple environments. Breached data stored in public clouds incurred the highest average breach cost at USD 5.17 million.

Strengthen prevention strategies with AI and automation

Applying AI and automation that support security prevention strategies, including in the areas of attack surface management, red-teaming and posture management, can help. These solutions can be adopted through fully managed security services.

Content

1. General info
 1. Type of audits
 2. Audit standards
 3. ITAF - Information Technology Assurance Framework
2. How to audit – hands on
 1. General computer controls
 2. ISO 27001
 3. Local legal requirements
3. Discussions on public cases
4. Train for the exam – Q&A

Course's objectives

- **Plan an audit** to determine whether information systems are protected, controlled, and provide value to the organization.
- **Conduct an audit** in accordance with IS audit standards and a risk-based IS audit strategy.
- **Communicate** audit progress, findings, results, and recommendations to stakeholders.
- **Conduct audit follow-up** to evaluate whether risks have been sufficiently addressed.
- Evaluate IT management and **monitoring of controls**.
- Utilize **data analytics tools** to streamline audit processes.
- Provide **consulting services** and guidance to the organization in order to improve the quality and control of information systems.
- Identify **opportunities for process improvement** in the organization's IT policies and practices.

I am ...

- **An auditor**
- **Security specialist**
- **Internal control team member**
- **CISO**
- **Client (user)**
- **Regulatory body**
- **Senior management**
- **Head of software development department**
- **...**

Type of audits

- **Compliance audits** Compliance audits include specific tests of controls to demonstrate **adherence to** specific regulatory or industry standards. Examples include Payment Card Industry Data Security Standard (PCI DSS) audits for companies that process credit card data and Health Insurance Portability and Accountability Act (HIPAA) audits for companies that handle health care data.
- **Financial audits** The purpose of a financial audit is to assess the **accuracy of financial reporting**. It often involves detailed, substantive testing, although increasingly, auditors are placing more emphasis on a risk- and control-based audit approach. This kind of audit relates to **financial information integrity and reliability**.
- **Operational audits** An operational audit is designed to **evaluate the internal control structure in a given process or area**. Examples include IS audits of application controls or logical security systems.
- **Administrative audits** These are oriented to assess **issues related to the efficiency of operational productivity within an organization**.
- **IS audits** This process collects and evaluates evidence to determine whether the **information systems and related resources adequately safeguard assets, maintain data and system integrity and availability, provide relevant and reliable information, achieve organizational goals effectively, and consume resources efficiently**. Also, do they have, in effect, internal controls that provide reasonable assurance that business, operational and control objectives will be met and that undesired events will be prevented, or detected and corrected, in a timely manner.
- **Forensic audits** Forensic auditing has been defined as **auditing specialized in discovering, disclosing and following up on fraud and crimes**. The primary purpose of such a review is the development of evidence for review by law enforcement and judicial authorities.
- **Integrated audits** An integrated audit combines **financial and operational audit steps**. It is performed to assess the overall objectives within an organization, related to financial information and assets' safeguarding, efficiency and compliance. **An integrated audit focuses on risk**. It involves a team of auditors with different skill sets working together to provide a comprehensive report.

Internal vs. External Audits

Internal audit

- The scope and objectives of the audit function within the organization and are not specific to a particular IS audit.
- The **audit charter** is a document approved by those charged with governance that defines the purpose, authority and responsibility of the internal audit activity. It must be approved by the highest level of management or the audit committee.

External audit

- The scope and objectives of the audit are documented in a formal contract or statement of work.
- An **engagement letter** is a formal document which defines an IS auditor's responsibility, authority and accountability for a specific assignment. It does not replace an audit charter.

IS Audit

IS auditing is the formal examination, interview and/or testing of information systems to determine whether:

- Information systems are in **compliance** with applicable laws, regulations, contracts and/or industry guidelines.
- IS data and information have appropriate levels of **confidentiality, integrity and availability**.
 - **Confidentiality**: Only authorized users and processes should be able to access or modify data
 - **Integrity**: Data should be maintained in a correct state and nobody should be able to improperly modify it, either accidentally or maliciously
 - **Availability**: Authorized users should be able to access data whenever they need to do so
- IS operations are being accomplished efficiently, and **effectiveness** targets are being met.

Some good reads:

<https://www.csoonline.com/article/3519908/the-cia-triad-definition-components-and-examples.html>

<https://www.isaca.org/resources/isaca-journal/past-issues/2011/data-integrity-information-security-s-poor-relation>

IS Audit Engagements

- **General control audits** are usually examinations in which management control practices and general controls are assessed for the adequacy of their design and tested for their effectiveness. As examinations, the performed audit steps and the obtained evidence serve as a basis for audit reports to include conclusions and opinions. [Although general control audits can be limited to a single-topic area such as change control or disaster recovery, the audits typically cover several topics reflecting an array of processes or functions.]
- Although **application audits** typically focus on the reliability, security and availability of the system, application audits may be limited to a particular aspect of the system, such as data integrity, data storage and recovery, or operational value. From an operational perspective, the scope may include an assessment of maintainability, program change control and disaster recovery.
- In the realm of system **development audits**, the three most common types of engagements :
 - Review of the development methodology, policy and procedures
 - Examination of development and implementation of a particular application system
 - Examination of deliverables and management controls at different phases, as the system is being developed.
- **Technical or special topic audits** tend to have more limited scopes and highly technical audit objectives. These engagements usually are more tightly focused than general control examinations and may be performed as reviews or examinations. As such, audit report content depends upon the breadth of audit scope and objectives, complexity and extent of audit work, audit evidence, required technical explanations and defined expectations of audit report users.

Terminology

- **Audit** - **Formal inspection** and verification to check whether a standard or set of guidelines is being followed, records are **accurate**, or **efficiency** and **effectiveness** targets are being met.
- **Assurance** - Pursuant to an accountable relationship between two or more parties, an IT audit and assurance professional is engaged to issue a written communication expressing a **conclusion** about the subject matters for which the accountable party is responsible. Assurance refers to a number of related activities designed to **provide the reader or user of the report with a level of assurance or comfort over the subject matter**.
- **Assessment** – A **broad review** of the different aspects of a company or function that includes elements not covered by a structured assurance initiative.

Types of Audit Engagements

- **Review** A review is designed to provide **limited assurance** about an assertion. As the name implies, a review consists primarily of review work **with less emphasis on testing** or verification. A review can be more process oriented, focusing on the appropriateness of the tasks and activities that the audit entity performs and the associated controls. The level of evidence that is gathered **is less than in an audit**, and **testing is generally limited or none is performed**. As a result, **reviews do not include audit opinions**. Instead, **conclusions may often be stated negatively**. For example, 'Nothing came to our attention to indicate that the assertion is not true'.
- **Examination** An information system audit can be performed as an examination, which is a **systematic process** by which a competent, independent person objectively obtains and evaluates evidence regarding assertions about an entity or event, processes, operations or internal controls, for the **purpose of forming an opinion** and providing a **report on the degree to which the assertions conform to an identified set of standards**. An examination is an **attestation process** that provides the **highest level of assurance** about an assertion that an auditor can provide. An examination encompasses gathering and evaluating **sufficient, competent evidence** and **performing appropriate tests** and other procedures to form the **opinion about an assertion** for presentation in an audit report.
- **Agreed-upon Procedures Engagement** In agreed-upon procedures engagements, a third party and the auditor **agree on specific procedures** that will be performed to obtain the evidence on which the third party is willing to rely **as a basis for a conclusion**. Depending on the requirements of the third party, the **agreed-upon level of evidence** may be significantly **limited or extensive**. The auditor may need to obtain a substantial amount of evidence; in some cases, more than that is required for an audit.

What is the most important skill an auditor should have?

19 responses

A word cloud of 19 responses to the question 'What is the most important skill an auditor should have?'. The words are arranged in a circular pattern, with 'good memory' and 'memory' being the most prominent. Other visible words include 'logical', 'critical fast thinking', 'out of the box thinking', 'problem solving', 'attention to details', 'jack of all trades', 'logical thinking', 'meticulous', 'knowledge', 'learn continuously', 'patience of steel', 'logic thinking', 'do things by the rules', 'attention to detail', 'fatigue resistance', and 'cirtical fast thinking'.

out of the box thinking
problem solving
attention to details
jack of all trades
logical thinking
good memory
memory
logical
critical fast thinking
cirtical fast thinking
fatigue resistance
knowledge
learn continuously
patience of steel
logic thinking
do things by the rules
attention to detail
meticulous

Auditor skills



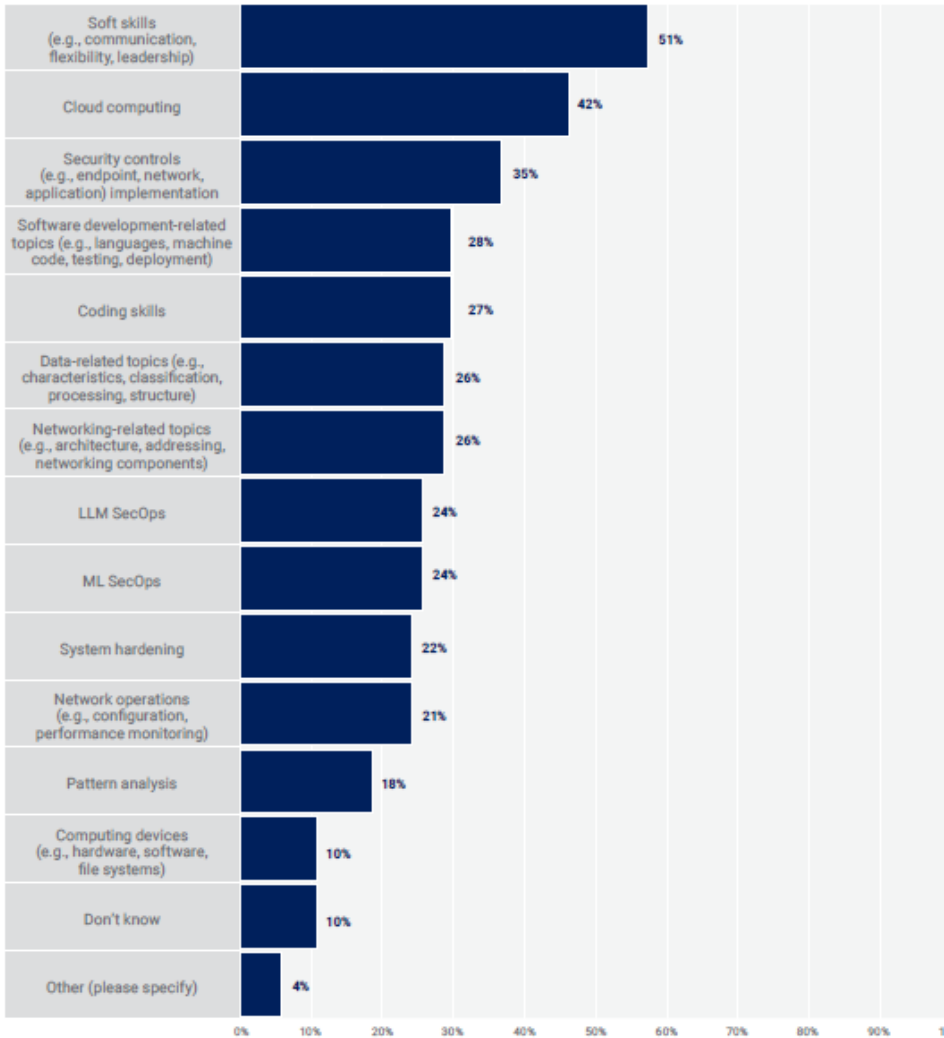
Adobe Acrobat
Document

[2024 ISACA State of
cybersecurity]

- **Analytical skills**—The ability to visualize, articulate and solve complex problems and concepts, and make decisions that make sense based on available information. Such skills include demonstration of the ability to apply logical thinking to gathering and analysing information, designing and testing solutions to problems, and formulating plans.
- **Client maintenance**—Includes the ability to effectively maintain a client during a permitted length of time for audit services and also cultivate the sustenance for the business of the professional
- **Managerial communications and/or public speaking**—Includes the communication skills that are employed when discussing audit scope, findings and recommendations
- **Interviewing skills**—Includes the effective gathering of information when interviewing management and completing control questionnaires
- **Negotiation skills and/or personal selling**—Includes the ability to convince management to implement recommendations for positive change
- **Business writing**—Includes the ability to produce concise, understandable and usable reports, presentation materials, and other written communications
- **Industrial psychology and/or behavioural science**—Includes the ability to understand and effectively manage human behaviour throughout the audit process
- **Project management/time budgeting**—Includes the ability to effectively and efficiently manage time and tasks during audits. Auditors are frequently evaluated on covering specific scopes within time lines and budgets.
- **Team building and team leading**—Includes the ability to effectively manage team activities with proper coordination and utilization of knowledge and skills of individual team members in the performance of an IS audit

FIGURE 19: Quantified Skill Gaps

What are the biggest skill gaps you see in today's cybersecurity professionals?



- Biggest skills gaps in today's cybersecurity profession

FIGURE 24: Top Five Soft Skills

Please choose the top five most important soft skills needed by security professionals in your organization

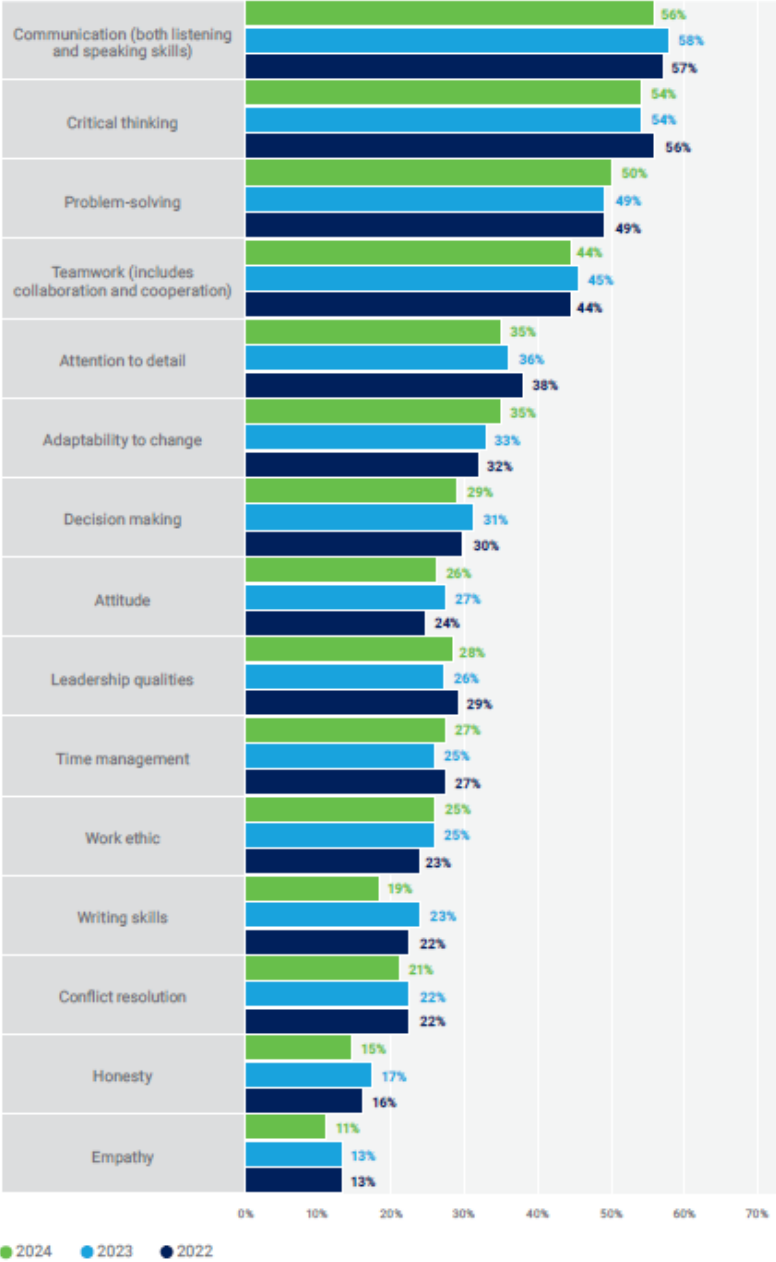


FIGURE 23: Top Five Security Skills

Please choose the top five most important security skills needed in your organization today.

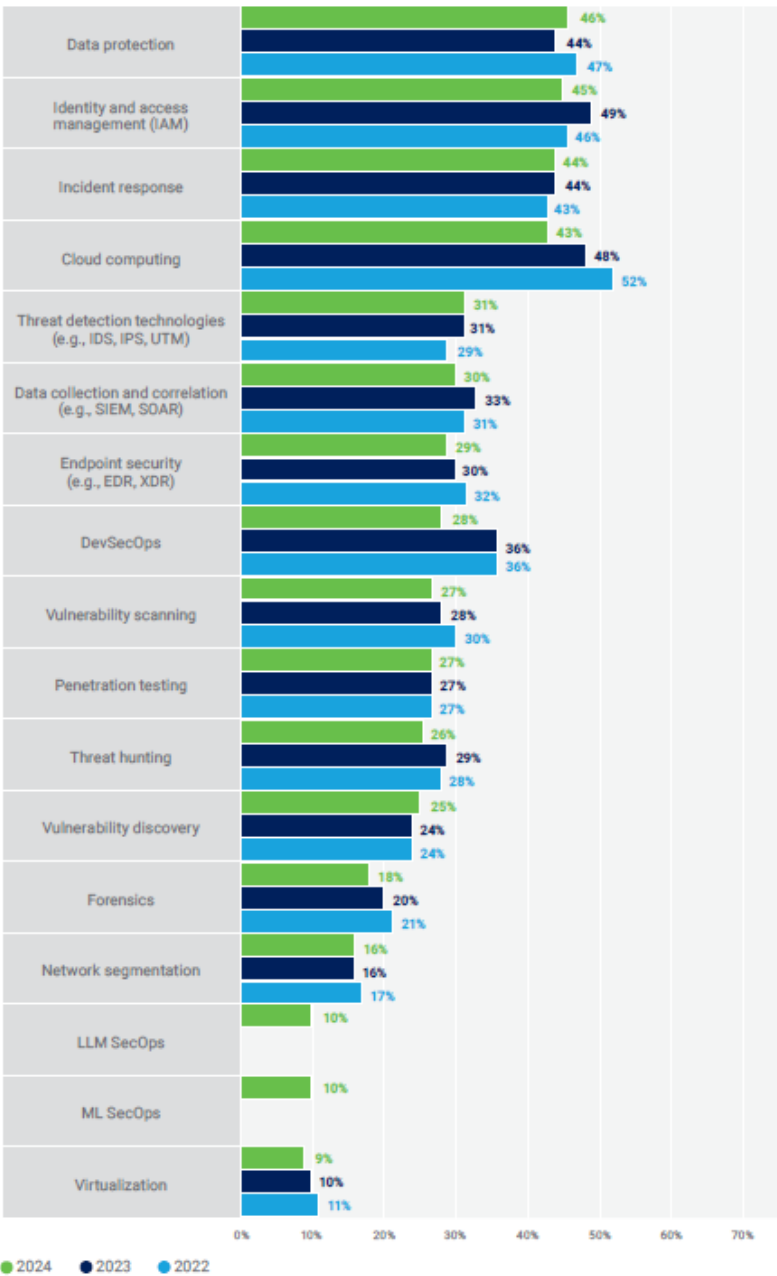
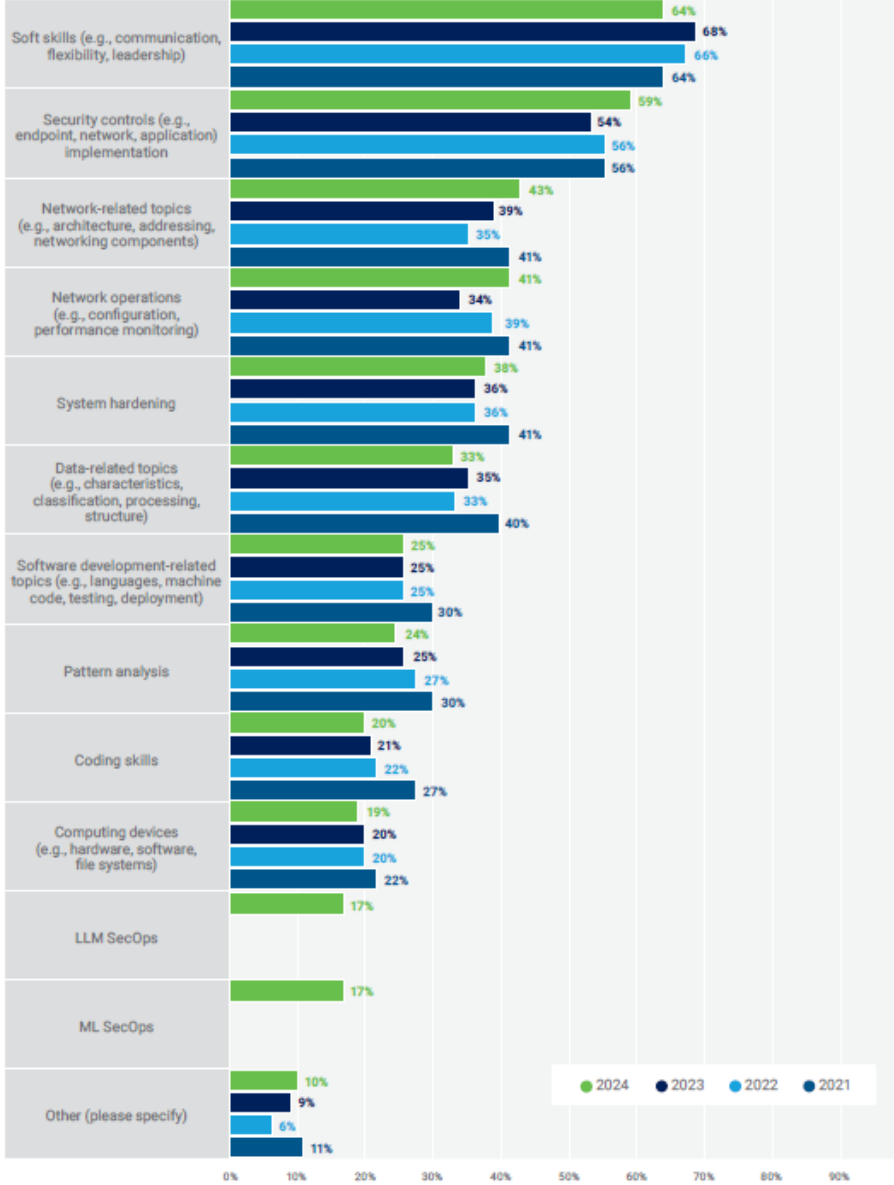


FIGURE 22: Skill Gaps Among Recent Graduates¹⁰

Which of the following skill gaps have you noticed among recent university graduates?



10 LLM SecOps and ML SecOps are new response options in 2024.

IS Auditor Skills

- ISACA IS Audit and Assurance Standards (ITAF) require that the IS auditor be **technically competent (1006 Proficiency)**.
- This is achieved through **continuing education**.
- CISA candidates do NOT need to memorize the ISACA IS Audit and Assurance Standards, Guidelines, and Tools and Techniques, but they must **be able to apply the standard**, guideline or ISACA Code of Professional Ethics in a given situation.

ISACA ethical code

Members and ISACA certification holders shall:

1. **Support** the implementation of, and **encourage compliance with**, appropriate standards and procedures for the effective governance and management of enterprise information systems and technology, including: audit, control, security and risk management.
2. Perform their duties with **objectivity, due diligence** and **professional care**, in accordance with professional standards.
3. **Serve in the interest of stakeholders in a lawful manner**, while maintaining high standards of conduct and character, and not discrediting their profession or the Association.
4. Maintain the **privacy** and **confidentiality** of information obtained in the course of their activities unless disclosure is required by legal authority. **Such information shall not be used for personal benefit or released to inappropriate parties.**
5. Maintain **competency** in their respective fields and agree to undertake only those activities they can reasonably expect to complete with the necessary **skills, knowledge** and **competence**.
6. **Inform appropriate parties of the results of work performed including the disclosure of all significant facts known to them that, if not disclosed, may distort the reporting of the results.**
7. **Support the professional education of stakeholders** in enhancing their understanding of the governance and management of enterprise information systems and technology, including: audit, control, security and risk management.

Failure to comply with this Code of Professional Ethics can result in an investigation into a member's or certification holder's conduct and, ultimately, in disciplinary measures.

Standards & guidelines for auditing

- International standards on auditing (ISA) issued by International Federation of Accountants (IFAC 1977)
- Generally Accepted Auditing Standards (GAAS)
- Statement on Standards for Attestation Engagements no. 18 (SSAE 18 is a GASS) published by AICPA (American Institute of Certified Public Accountants 1887)
 - Trust Services Criteria (2014)/ Cybersecurity Risk Management Reporting Framework (2017)
 - System and Organization Controls (SOC) for Service Organizations and SOC for Cybersecurity Reporting Framework.
- Standards and guidelines specific to a region/country

Standards, requirements, guides on IT&IS

- Internal control objectives; internal control and documentation of IS, COCO (Guidance on control), COSO (Committee of Sponsoring Organizations of the Treadway Commission), Sarbanes-Oxley Act
- ISO 27000 series
- COBIT (Control Objectives for Information and Related Technologies) – ISACA
- ITAF – Information Technology Audit Framework (ITAF), published by ISACA
- NIST (National Institute of Standards and Technology) – many publication; 2024 NIST Cybersecurity framework
- Legislation requirements (IB, SEP, electronic archiving, GDPR/ data privacy, etc)

Additional resources:

History of cybersecurity: material available on portal.ism.ase.ro

History of IT audit material available on portal.ism.ase.ro



ITAF

31



ITAF (Information Technology Audit Framework)

The Information Technology Audit Framework (ITAF), published by ISACA, is a comprehensive and **good-practice-setting model**.

- **Guidance on the design, conduct and reporting** of IT audit and assurance assignments;
- **Terms and concepts** specific to IT assurance;
- **IT audit and assurance professional roles and responsibilities;**
- knowledge and skills.



ITAF (Information Technology Assurance Framework)

- **To whom does ITAF apply** ITAF applies to individuals who act in the capacity of IS audit and assurance professionals and are engaged in providing assurance over some components of IS applications and infrastructure. However, care has been taken to design these standards, guidelines, and tools and techniques in a manner that may also be useful and provide benefits to a wider audience, including users of IS audit and assurance reports.
- **When should ITAF be used?** The application of the framework is a prerequisite to conducting IS audit and assurance work. The standards are mandatory. The guidelines, tools and techniques are designed to provide non-mandatory assistance in performing assurance work.
- **Where should ITAF IS audit and assurance standards and related guidance be used?** ITAF's design recognizes that IS audit and assurance professionals are faced with different requirements and types of assignments—ranging from leading an IS-focused audit to contributing to a financial or operational audit. **ITAF is applicable to any formal IS audit or assessment engagement.**
- **Does ITAF address requirements for consultative and advisory work?** In addition to assessment work, IS audit and assurance professionals frequently undertake consultative and advisory engagements for their employers or on behalf of clients. These assignments usually result in an assessment of a particular area; identification of issues, concerns or weaknesses; and the development of recommendations. For a number of reasons, including nature of the work, scope of the engagement, independence and degree of testing, the work is not considered an audit and, therefore, the IS audit and assurance professional does not issue a formal audit report. ITAF has not been designed to address specific requirements with respect to this consultative and advisory work.



ITAF (Information Technology Assurance Framework)

Standards

Must be followed by the IS auditor

Guidelines

Provides assistance on how the auditor can implement standards

Tools & techniques

Provide examples on steps an auditor may follow to implement standards

ITAF (Information Technology Audit Framework) - A Professional Practices Framework for IT Audit

GENERAL STANDARDS	PERFORMANCE STANDARDS	REPORTING STANDARDS
1001/ 2001 Audit Charter	1201/ 2201 Risk Assessment in Planning	1401/ 2401 Reporting
1002/ 2002 Organisational Independence	1202/ 2202 Audit Scheduling	1402/ 2402 Follow-up Activities
1003/ 2003 Auditor objectivity	1203/ 2203 Engagement planning	
1004/ 2004 Reasonable Expectation	1204/ 2204 Performance and supervision	
1005/ 2005 Due Professional Care	1205/ 2205 Evidence	
1006/ 2006 Proficiency	1206/ 2206 Using the Work of Other Experts	
1007/ 2007 Assertions	1207/ 2207 Irregularity and Illegal Acts	
1008/ 2008 Criteria		



ITAF (Information Technology Audit Framework) - A Professional Practices Framework for IT Audit

GENERAL STANDARDS

Audit Charter	Specific and formal purpose, responsibility, authority and accountability
Organisational Independence	No conflicts of interest in all matters related to audit engagement Clear functional and administrative reporting relationship
Auditor objectivity	IT audit and assurance practitioners shall be objective in all matters related to audit and assurance engagements.
Reasonable Expectation	IT audit and assurance practitioners shall have reasonable expectation that the engagement can be completed as per the agreed requirements, scope of engagement enable a conclusion and management understand its obligations and responsibilities
Due Professional Care	Auditors will exercise due diligence and professional care , will maintain high standards of conduct and character, and they will refrain from engaging in acts that may discredit themselves or the profession.
Proficiency	IT audit and assurance practitioners shall possess adequate professional competence to perform the work required
Assertions	IT audit and assurance practitioners shall review the assertions against which the subject matter will be assessed to ensure those are sufficient, valid and relevant
Criteria	IT audit and assurance practitioners shall select criteria, against which the subject matter will be assessed, that are objective, complete, relevant, reliable, measurable, understandable, widely recognized, authoritative, and understood by, or available to, all readers and users of the report.

Question on independence (menti.com)

An auditor is invited to participate to the process of designing a new critical application of an organization. By accepting this, would the auditor lose his independence when he will be needed to audit the application running in the production environment?

- A. Yes. An auditor should not be involved during the process of designing or developing of the application
- B. No. As long as he only ensure awareness for the team regarding the need of control design.

Question on objectivity (menti.com)

For the last 9 years an auditor was working as external auditor for the same client. During this time, he develop a personal relationship with the CIO of the audited organization. In the 10th year, during the regular annual audit he identified a major security finding with significant potential impact on the business. When disclosed, CIO asked the auditor to decrease the finding classification when presenting final report, being concerned that such results would bring him troubles.

- A. The auditor accepted, as CIO is a close friend for him, not being comfortable with potentially jeopardizing his job
- B. The auditor accepted, as there is not so much difference between major and medium'
- C. The auditor refused , as the request is unethical based on the code of his profession.



ITAF (Information Technology Audit Framework) - A Professional Practices Framework for IT Audit

PERFORMANCE STANDARDS	
Risk Assessment in Planning	The IT audit and assurance function shall use an appropriate risk assessment approach and supporting methodology to develop the overall IT audit plan and to determine priorities for the effective allocation of IT audit resources.
Audit Scheduling	The IT audit and assurance function shall establish an overall strategic plan resulting in short-term and long-term audit schedules .
Engagement Planning	IT audit and assurance practitioners shall plan each IT audit and assurance engagement to address the nature, timing and extent of audit procedures to be performed .
Performance and Supervision	IT audit and assurance practitioners shall conduct the work in accordance with the approved IT audit plan and provide supervision to IT audit staff for whom they have supervisory responsibility to accomplish audit objectives
Evidence	IT audit and assurance practitioners shall obtain sufficient and appropriate evidence to draw reasonable conclusions.
Using the Work of Other Experts	IT audit and assurance practitioners shall consider using the work of other experts for the engagement, where appropriate.
Irregularities and Illegal Acts	IT audit and assurance practitioners shall consider the risk of irregularities and illegal acts during the engagement.

Performing an audit engagement

PLANNING: 2201

Key Points:

- Defines audit scope, objectives, and criteria.
- Requires understanding of IT risks and controls.
- Ensures adequate resources and methodologies are allocated.

[Risk assessment]
[Audit scheduling]
[Engagement planning]

PERFORMANCE OF AUDIT WORK : ITAF 2202

Key Points:

- Establishes guidelines for executing audit procedures.
- Includes data gathering, testing, and evidence collection.
- Emphasizes professional skepticism and due diligence.

[Performance and supervision]
[Evidence]
[Using the work of others]
[Irregularities and illegal acts]

REPORTING STANDARDS: ITAF 2203

Key Points:

- Specifies requirements for clear, accurate, and complete audit reports.
- Findings must be factual, well-documented, and actionable.
- Recommendations should align with business objectives and risks.

[Reporting]
[Follow up]

Control Objectives and Control Measures

Control Objectives

An **objective** of one or more operational area(s) or role(s) to be achieved, in order to contribute to the fulfillment of strategic goal(s) of the company. That is, the control objective is such a goal, that is explicitly related to the strategy of the company.

Control measures

An **activity** contributing to the fulfillment of a control objective. Both the control objective and control measure serve the decomposition of the strategic-level goals into such lower-level goals and activities, that can be assigned as tasks to the staff. This assignment can take the form of a role description in a job description.

Control Objectives and Control Measures

Control Objectives

Data is appropriately **managed** to provide **reasonable assurance** that financial data remains **complete, accurate, and valid** throughout the update and storage process.

Control measures

- Management and users **plan** and schedule **backup** and **retention** of data and erasure and release of media when retention is no longer required.
- Management periodically **reviews** retention and releases records.
- All media (tapes, manuals, guides) are properly **labelled** and **timely** stored in a secured environmentally **controlled** location to minimize risk that data is lost.
- Backups are archived **off-site** to minimize risk that data is lost.
- Ongoing **readability** of backup and retained data is tested periodically through restoration or other methods.

Control Classification

Type	Definition
Preventive	• Detect problems before they arise. • Monitor both operation and inputs. • Attempt to potential problems before they occur and make adjustments. • Prevent an error, omission or malicious act from occurring. • Segregate duties (deterrent factor). • Control access to physical facilities. • Use well-designed documents (prevent errors).
Detective	• Use controls that detect and report the occurrence of an error, omission or malicious act.
Corrective	• Minimize the impact of a threat. • Remedy problems discovered by detective controls. • Identify the cause of a problem. • Correct errors arising from a problem. • Modify the processing system(s) to minimize future occurrences of the problem.

Question (menti.com)

An IS auditor notes that failed login attempts to a core financial system are automatically logged and the logs are retained for a year by the organization. This logging is:

- A. An effective preventive control.
- B. A valid detective control.
- C. Not an adequate control.
- D. A corrective control.

General Controls

- **Internal accounting controls** that concern the safeguarding of assets and reliability of financial information
- **Operational controls** that concern day-to-day operations, functions and activities
- **Administrative controls** that concern operational efficiency in a functional area and adherence to management policies
- **Organizational (security) policies and procedures** to ensure proper usage of assets
- **Overall policies** for the design and use of adequate documents and records
- **Access and use procedures and practices**
- **Physical and logical security policies** for all facilities

IS Control Objectives

- Statements of the **desired result or purpose to be achieved** by implementing controls around information systems processes.
- Policies, procedures, practices and organizational structures designed to provide **reasonable assurance that business objectives will be achieved, and undesired events will be prevented or detected and corrected.**
- **System development life cycle (SDLC)** processes are established, in place and **operating effectively**
- **Integrity** of general operating system (OS) environments, of sensitive and critical application system environments
- Appropriate **identification** and **authentication** of users
- The **efficiency and effectiveness** of **operations**
- **Integrity** and **reliability** of systems by implementing effective change management procedures complying with the users' requirements, organizational policies and procedures, and applicable laws and regulations (compliance objectives)
- Ensuring **availability** of IT services by developing efficient business continuity plans (BCPs), disaster recovery plans (DRPs), that include backup and recovery processes
- Enhancing **protection** of **data and systems** by developing an incident response plan
- Ensuring that outsourced IS processes and services have clearly defined **service level agreements** (SLAs) and contract terms and conditions to ensure the organization's assets are properly protected and meet business goals and objectives

IS-Specific control areas

- **Strategy and direction** of the IT function
- General organization and management of the IT function
- **Access to IT resources**, including data and programs
- **Systems development methodologies** and **change control**
- **Operations procedures**
- **Physical access controls**
- **Business continuity planning** (BCP)/disaster recovery planning (DRP)
- **Networks and communications**
- Database **administration**
- **Protection and detective mechanisms** against internal and external attacks

Business Process Applications and Controls

These controls may be a combination of:

- Management
- Programmed
- Manual controls

PLANNING: 2201

- Defines audit scope, objectives, and criteria.
- Requires understanding of IT risks and controls.
- Ensures adequate resources and methodologies are allocated.

PERFORMANCE OF AUDIT WORK : ITAF 2202

- Establishes guidelines for executing audit procedures.
- Includes data gathering, testing, and evidence collection.
- Emphasizes professional skepticism and due diligence.

REPORTING STANDARDS: ITAF 2203

- Specifies requirements for clear, accurate, and complete audit reports.
- Findings must be factual, well-documented, and actionable.
- Recommendations should align with business objectives and risks.

[Risk Assessment in IT Audit]

- Identify and analyze **IT risks** affecting business objectives.
- Assess **impact and likelihood** of IT-related threats.
- Align audit efforts with **organizational risk appetite**.

[Audit Scheduling & Resource Allocation]

- Establish an **audit calendar** based on risk prioritization.
- Ensure **availability of skilled resources** and tools.
- Consider dependencies, regulatory deadlines, and **business cycles**.

[Engagement Planning]

- Define **audit scope, objectives, and methodology**.
- Understand **IT environment**, infrastructure, and key controls.
- Communicate expectations with stakeholders.

[Audit Performance & Execution]

- Conduct **fieldwork** following the approved audit plan.
- Identify control weaknesses and security gaps.
- Maintain **professional skepticism and independence**.

[Gathering and Evaluating Evidence]

- Collect **sufficient, reliable, relevant, and useful** audit evidence.
- Use **sampling techniques, automated tools, and forensic analysis**.
- Document findings **clearly and concisely**.

[Using the Work of Others]

- Rely on **external auditors, internal teams, or third-party assessments**.
- Ensure their work is **objective, competent, and well-documented**.
- Validate **key assumptions and conclusions**.

[Handling Irregularities and Fraud]

- Identify potential **fraud, noncompliance, or ethical violations**.
- Escalate **serious issues to appropriate authorities**.
- Maintain confidentiality and follow **legal reporting obligations**.

[Reporting Audit Findings]

- Prepare a **clear, concise, and fact-based audit report**.
- Include **risk-based recommendations** for remediation.
- Communicate findings to **senior management and stakeholders**.

[Follow-Up on Audit Recommendations]

- Track **management's corrective actions** and implementation status.
- Conduct **post-audit reviews** to assess improvements.
- Ensure **continuous enhancement of IT controls**.

Risks

ITAF 2201.5 Audit risk

- **Inherent:** As it relates to audit risk, it is the risk level or exposure of the process/entity to be audited without considering the controls that management has implemented. Inherent risk exists independent of an audit and can occur because of the nature of the business.
- **Control:** The risk that a material error exists that would not be prevented or detected **on a timely basis** by the system of internal controls. For example, the control risk associated with manual reviews of computer logs can be high because activities requiring investigation are often easily missed due to the volume of logged information. The control risk associated with computerized data validation procedures is ordinarily low if the processes are consistently applied.
- **Detection:** The risk that material errors or misstatements that have occurred will not be detected by an IS auditor.
- **Overall detection risk:** The probability that information or financial reports may contain material errors and that the auditor may not detect an error that has occurred. An objective in formulating the audit approach is to limit the audit risk in the area under scrutiny so the overall audit risk is at a sufficiently low level at the completion of the examination.

Examples of risks arising from IT

- Unauthorized access
- Theft or destruction of hardware
- Inappropriate use of IT resources
- Implementation of developments containing bugs or not matching the business' requirements
- Loss/theft of confidential data
- Unavailability of systems and applications
- Fraudulent or unintentional data alteration or entry
- Non-compliance with applicable rules and regulations
- Implementation of fraudulent changes
- Incoherence of the content of the backups with the business requirements
- Errors in financially and business critical data

Risk response options

- **Risk mitigation** – Applying appropriate controls to reduce the risk
- **Risk acceptance** – Knowingly and objectively not taking action, providing the risk clearly satisfies the organization's policy and criteria for risk acceptance
- **Risk avoidance** – Avoiding risk by not allowing actions that would cause the risk to occur
- **Risk transfer/sharing** – Transferring the associated risk to other parties

PLANNING: 2201

- Defines audit scope, objectives, and criteria.
- Requires understanding of IT risks and controls.
- Ensures adequate resources and methodologies are allocated.

PERFORMANCE OF AUDIT WORK : ITAF 2202

- Establishes guidelines for executing audit procedures.
- Includes data gathering, testing, and evidence collection.
- Emphasizes professional skepticism and due diligence.

REPORTING STANDARDS: ITAF 2203

- Specifies requirements for clear, accurate, and complete audit reports.
- Findings must be factual, well-documented, and actionable.
- Recommendations should align with business objectives and risks.

[Risk Assessment in IT Audit]

- Identify and analyze **IT risks** affecting business objectives.
- Assess **impact and likelihood** of IT-related threats.
- Align audit efforts with **organizational risk appetite**.

[Audit Scheduling & Resource Allocation]

- Establish an **audit calendar** based on risk prioritization.
- Ensure **availability of skilled resources** and tools.
- Consider dependencies, regulatory deadlines, and **business cycles**.

[Engagement Planning]

- Define **audit scope, objectives, and methodology**.
- Understand **IT environment**, infrastructure, and key controls.
- Communicate expectations with stakeholders.

[Audit Performance & Execution]

- Conduct **fieldwork** following the approved audit plan.
- Identify control weaknesses and security gaps.
- Maintain **professional skepticism and independence**.

[Gathering and Evaluating Evidence]

- Collect **sufficient, reliable, relevant, and useful** audit evidence.
- Use **sampling techniques, automated tools, and forensic analysis**.
- Document findings **clearly and concisely**.

[Using the Work of Others]

- Rely on **external auditors, internal teams, or third-party assessments**.
- Ensure their work is **objective, competent, and well-documented**.
- Validate **key assumptions and conclusions**.

[Handling Irregularities and Fraud]

- Identify potential **fraud, noncompliance, or ethical violations**.
- Escalate **serious issues to appropriate authorities**.
- Maintain confidentiality and follow **legal reporting obligations**.

[Reporting Audit Findings]

- Prepare a **clear, concise, and fact-based audit report**.
- Include **risk-based recommendations** for remediation.
- Communicate findings to **senior management and stakeholders**.

[Follow-Up on Audit Recommendations]

- Track **management's corrective actions** and implementation status.
- Conduct **post-audit reviews** to assess improvements.
- Ensure **continuous enhancement of IT controls**.

Audit techniques

ITAF 2205 Evidence

- The **tests of controls** are performed using **walkthrough testing**, designed to evaluate the **operating effectiveness** of controls in preventing, detecting and correcting material deficiencies affecting the Company's processes.
- The **inspection** involves **examining records or documents**, whether internal or external, in **paper** form, **electronic** form, or other media. Inspection of records and documents provides evidence of varying degrees of reliability, depending on their nature and source and on the effectiveness of the controls over their production. Inspection technique can be split into **document inspection** and **site inspection**.
- The **observation** consists in overseeing a process or procedure being performed by the Company. For example, the observation of the performance of control activities. **Observation provides evidence about the performance of a process or procedure, but is limited to the point in time, at which observation takes place, and by the fact that the act of being observed may affect how the process or procedure is performed.**
- Our **inquiry and analysis** consist in seeking information from knowledgeable persons, both technical and non-technical, which may provide us with details previously not possessed. It may range from **formal written inquiries to informal oral inquiries**. Inquiries were performed during the meetings with relevant persons from the Company.

Testing methods

ITAF Companion Performance
Guidelines 2208: Information
Technology Audit Sampling.

Compliance testing (test of controls): An audit procedure designed to evaluate the operating effectiveness of controls in preventing or detecting and correcting material weaknesses. *Examples of compliance testing of controls, where sampling could be considered, include user access rights, program change control procedures, procedure documentation, program documentation, follow-up on exceptions, review of logs and software licences audits.*

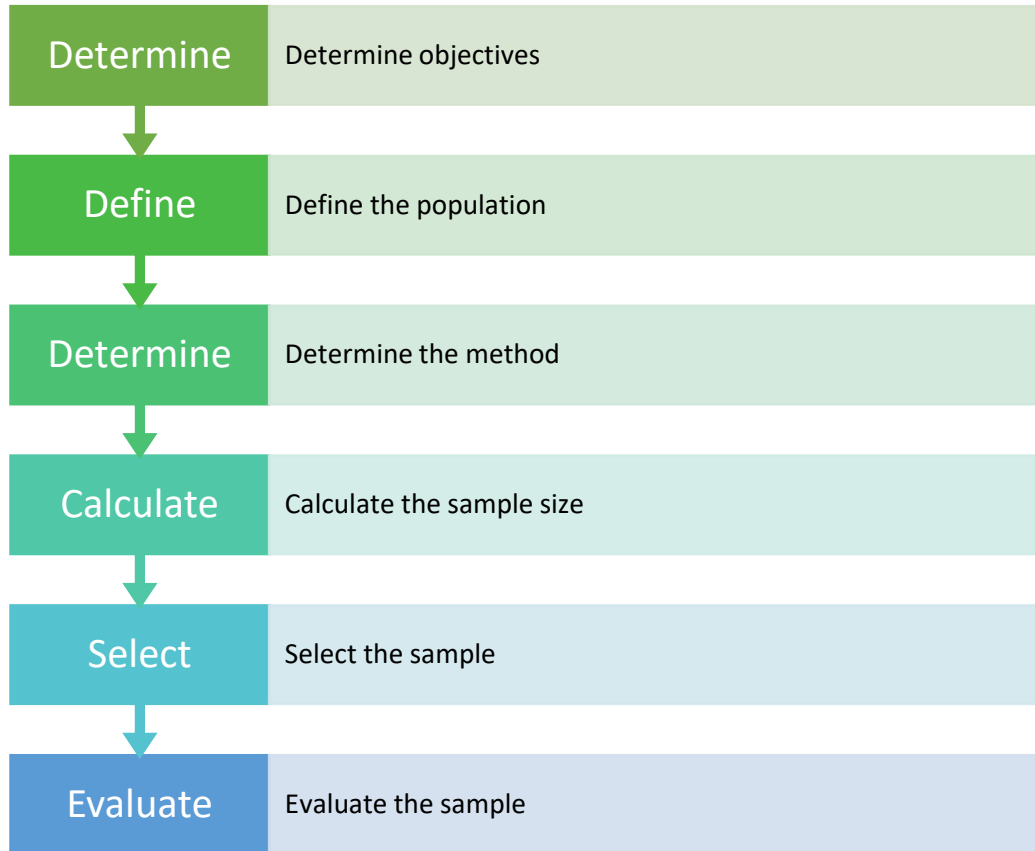
Substantive testing (test of details): An audit procedure designed to detect material weaknesses at the assertion level. *Examples of substantive tests, where sampling could be considered, include reperformance of a complex calculation*

Testing methods

ITAF Companion Performance
Guidelines 2208: Information
Technology Audit Sampling.

- **Points to remember: in any give scenario,**
- ... compliance testing will be performed first. Substantive testing will be the next step.
- ... compliance testing test controls, while substantive testing tests details.
- ... compliance testing checks for the presence of controls whereas substantive testing checks the integrity of contents i.e. test of individual transactions.
- ... outcome/result of compliance testing will form the basis for planning of substantive testing.
- ... attribute sampling method (either control is present or absent) will be useful when testing for compliance.

Sampling steps



ITAF Companion Performance Guidelines 2208:
Information Technology Audit Sampling.

Statistical sampling methods

Simple random sampling—Ensures that all combinations of sampling units in the population have an equal chance of selection.

Systematic sampling—Involves selecting sampling units using a fixed interval between selections, with the first interval having a random start.

Stratified random sampling—Ensures that all sampling units in each subgroup have a known chance of selection.

Nonstatistical sampling methods:

Haphazard sampling—Practitioners select the sample without following a structured technique, while avoiding any conscious bias or predictability. Analysis of a haphazard sample should not be relied on to form a conclusion on the entire population.

Judgmental sampling—Practitioners place a bias on the sample. A judgmental sample is not statistically based, and results should not be extrapolated over the population, because the sample is unlikely to be representative of the population as a whole.

Evidence

ITAF 1205/ 2205 Evidence

- Evidence is any information used by the IS auditor to determine whether the entity or data being audited follows the established criteria or objectives and **supports audit conclusions**.
- Some types of evidence are more reliable than others. **Reliability** is determined by:
 - The **independence** of the evidence provider
 - The **qualifications** of the evidence provider
 - The **objectivity** of the evidence
 - The **timing** of the evidence
- The IS auditor must focus on the objectives of the audit and not on the nature of the evidence.
- Evidence is considered competent when it is both **valid and relevant**.

Data analytics

ITAF 2205/ 2207 Evidence/ Irregularities
& illegal acts

- Determine the operational effectiveness of the current control environment.
- Determine the **effectiveness of antifraud procedures** and controls.
- Identify **business process errors**.
- Identify business process improvements and inefficiencies in the control environment.
- Identify **exceptions or unusual business rules**.
- Identify **fraud**.
- Identify areas where **poor data quality exists**.
- Perform risk assessment at the planning phase of an audit.

Using the Services of Other Auditors and Experts

ITAF 1206/ 2206 Using the work of
other experts

- Restrictions on outsourcing of audit/security services provided by laws and regulations
- Audit charter or contractual stipulations
- **Impact** on overall and specific IS audit objectives
- **Impact** on IS audit risk and professional liability
- **Independence** and **objectivity** of other auditors and experts
- **Professional competence, qualifications** and **experience**
- **Scope of work** proposed to be outsourced and approach
- Supervisory and audit management controls

CAATTs

Computer-assisted Auditing Tools and Techniques

ITAF 2205/ 2207 Evidence/ Irregularities
& illegal acts

- CAATs help IS auditors collect sufficient, relevant and useful evidence that may only exist in electronic form.
- CAATs is the practice of analysing large volumes of data looking for anomalies
- They are particularly useful when auditing systems have different hardware and software environments, data structures, record formats or processing functions.
- Tools and Techniques
 - Generalized audit software (GAS)
 - Utility software
 - Debugging and scanning software
 - Test data
 - Application software tracing and mapping
 - Expert systems
 - BI
 - SAS etc

Additional resources available here: en.wikipedia.org/wiki/Computer-aided_audit_tools



ITAF (Information Technology Audit Framework) - A Professional Practices Framework for IT Audit

REPORTING STANDARDS

Reporting

IT audit and assurance practitioners shall provide a report to **communicate** the results of each engagement

Follow-up Activities

IT audit and assurance practitioners shall **monitor** and periodically report on management's progress on findings and recommendations

PLANNING: 2201

- Defines audit scope, objectives, and criteria.
- Requires understanding of IT risks and controls.
- Ensures adequate resources and methodologies are allocated.

PERFORMANCE OF AUDIT WORK : ITAF 2202

- Establishes guidelines for executing audit procedures.
- Includes data gathering, testing, and evidence collection.
- Emphasizes professional skepticism and due diligence.

REPORTING STANDARDS: ITAF 2203

- Specifies requirements for clear, accurate, and complete audit reports.
- Findings must be factual, well-documented, and actionable.
- Recommendations should align with business objectives and risks.

[Risk Assessment in IT Audit]

- Identify and analyze **IT risks** affecting business objectives.
- Assess **impact and likelihood** of IT-related threats.
- Align audit efforts with **organizational risk appetite**.

[Audit Scheduling & Resource Allocation]

- Establish an **audit calendar** based on risk prioritization.
- Ensure **availability of skilled resources** and tools.
- Consider dependencies, regulatory deadlines, and **business cycles**.

[Engagement Planning]

- Define **audit scope, objectives, and methodology**.
- Understand **IT environment**, infrastructure, and key controls.
- Communicate expectations with stakeholders.

[Audit Performance & Execution]

- Conduct **fieldwork** following the approved audit plan.
- Identify control weaknesses and security gaps.
- Maintain **professional skepticism and independence**.

[Gathering and Evaluating Evidence]

- Collect **sufficient, reliable, relevant, and useful** audit evidence.
- Use **sampling techniques, automated tools, and forensic analysis**.
- Document findings **clearly and concisely**.

[Using the Work of Others]

- Rely on **external auditors, internal teams, or third-party assessments**.
- Ensure their work is **objective, competent, and well-documented**.
- Validate **key assumptions and conclusions**.

[Handling Irregularities and Fraud]

- Identify potential **fraud, noncompliance, or ethical violations**.
- Escalate **serious issues to appropriate authorities**.
- Maintain confidentiality and follow **legal reporting obligations**.

[Reporting Audit Findings]

- Prepare a **clear, concise, and fact-based audit report**.
- Include **risk-based recommendations** for remediation.
- Communicate findings to **senior management and stakeholders**.

[Follow-Up on Audit Recommendations]

- Track **management's corrective actions** and implementation status.
- Conduct **post-audit reviews** to assess improvements.
- Ensure **continuous enhancement of IT controls**.

Communication of results

ITAF 1401/ 2401 Reporting

- Audit results are communicated in an exit meeting with management.
- Responsibilities of the IS auditor:
 - Ensure that the **facts** presented in the report **are correct**.
 - Ensure that the **recommendations are realistic and cost-effective**, and if not, seek **alternatives** through negotiation with auditee management.
 - Recommend **implementation dates** for agreed upon recommendations.
- The IS auditor can present the results of the audit in an executive summary or a visual presentation.

Audit report

ITAF 1401/ 2401 Reporting

- **An introduction to the report**, including the audit **objectives**, **limitations** and **scope**, the **period** of audit coverage, and a general **statement** on the **procedures** conducted and **processes** examined during the audit, followed by a **statement** on the IS audit **methodology** and guidelines
- **Audit findings**, often grouped in sections by materiality and/or intended recipient, and associated **recommendations**
- The IS auditor's **overall conclusion** and **opinion** on the adequacy of controls and procedures, and the actual potential risk identified as a consequence of detected deficiencies
- The IS auditor's reservations or **qualifications** with respect to the audit

Audit documentation

ITAF 2205.5 Preparing audit
documentation

- Audit documentation provides the necessary evidence that **support the audit findings and conclusions**.
- It should be **clear, complete, and easily retrievable**.
- It is the **property of the auditing entity** and should only be accessible to authorized personnel.
- All audit documentation should be:
 - Dated
 - Initialed
 - Page-numbered
 - Self-contained
 - Properly labeled
 - Kept in custody

Follow up activities

ITAF 1402/ 2402 Performance & Supervision

- Auditing is an ongoing process.
- It is the IS auditor's responsibility to ensure that **management has taken appropriate corrective actions.**
- A follow-up program should be implemented to manage follow-up activities.
- When the follow-up occurs depends on the criticality of the audit findings.
- **Results of the follow-up should be communicated to the appropriate level of management.**

IT audit and assurance Tools and Techniques

Audit Program

Cybersecurity Audit Program: Based on the NIST Cybersecurity Framework 2.0 | Digital | English

ISACA has updated its Cybersecurity Audit Program, adapted from the National Institute of Standards and Technology (NIST) Cybersecurity Framework 2.0 (released in February 2024).

Audit Program

Artificial Intelligence Audit Toolkit | Digital | English

As the use of AI increases and becomes more integral in enterprise product and service delivery, it will come under more audit scrutiny.

Audit Program

Zero Trust Audit Program | Digital | English

The Zero Trust Audit Program references various areas of focus that should be reviewed to determine the effectiveness of a Zero Trust program.

Audit Program

Google Cloud Platform Audit Program | Digital | English

With the continued growth and adoption of Google® Cloud

- These documents provide additional guidance for IT audit and assurance professionals and consist, among other things, of white papers, IT audit/assurance programs, reference books and the COBIT® 2019 family of products.
- The tools and techniques *documents* provide information on how to meet the standards when performing IS auditing work but do not set requirements.
 - Creating audit programs
 - IS audit reporting

How to audit

General computer
controls



PLANNING: 2201

- Defines audit scope, objectives, and criteria.
- Requires understanding of IT risks and controls.
- Ensures adequate resources and methodologies are allocated.

PERFORMANCE OF AUDIT WORK : ITAF 2202

- Establishes guidelines for executing audit procedures.
- Includes data gathering, testing, and evidence collection.
- Emphasizes professional skepticism and due diligence.

REPORTING STANDARDS: ITAF 2203

- Specifies requirements for clear, accurate, and complete audit reports.
- Findings must be factual, well-documented, and actionable.
- Recommendations should align with business objectives and risks.

[Risk Assessment in IT Audit]

- Identify and analyze **IT risks** affecting business objectives.
- Assess **impact and likelihood** of IT-related threats.
- Align audit efforts with **organizational risk appetite**.

[Audit Scheduling & Resource Allocation]

- Establish an **audit calendar** based on risk prioritization.
- Ensure **availability of skilled resources** and tools.
- Consider dependencies, regulatory deadlines, and **business cycles**.

[Engagement Planning]

- Define **audit scope, objectives, and methodology**.
- Understand **IT environment**, infrastructure, and key controls.
- Communicate expectations with stakeholders.

[Audit Performance & Execution]

- Conduct **fieldwork** following the approved audit plan.
- Identify control weaknesses and security gaps.
- Maintain **professional skepticism and independence**.

[Gathering and Evaluating Evidence]

- Collect **sufficient, reliable, relevant, and useful** audit evidence.
- Use **sampling techniques, automated tools, and forensic analysis**.
- Document findings **clearly and concisely**.

[Using the Work of Others]

- Rely on **external auditors, internal teams, or third-party assessments**.
- Ensure their work is **objective, competent, and well-documented**.
- Validate **key assumptions and conclusions**.

[Handling Irregularities and Fraud]

- Identify potential **fraud, noncompliance, or ethical violations**.
- Escalate **serious issues to appropriate authorities**.
- Maintain confidentiality and follow **legal reporting obligations**.

[Reporting Audit Findings]

- Prepare a **clear, concise, and fact-based audit report**.
- Include **risk-based recommendations** for remediation.
- Communicate findings to **senior management and stakeholders**.

[Follow-Up on Audit Recommendations]

- Track **management's corrective actions** and implementation status.
- Conduct **post-audit reviews** to assess improvements.
- Ensure **continuous enhancement of IT controls**.

Audit techniques

- The **tests of controls** are performed using **walkthrough testing**, designed to evaluate the **operating effectiveness** of controls in preventing, detecting and correcting material deficiencies affecting the Company's processes.
- The **inspection** involves **examining records or documents**, whether internal or external, in **paper** form, **electronic** form, or other media. Inspection of records and documents provides evidence of varying degrees of reliability, depending on their nature and source and on the effectiveness of the controls over their production. Inspection technique can be split into **document inspection** and **site inspection**.
- The **observation** consists in overseeing a process or procedure being performed by the Company. For example, the observation of the performance of control activities. **Observation provides evidence about the performance of a process or procedure, but is limited to the point in time, at which observation takes place, and by the fact that the act of being observed may affect how the process or procedure is performed.**
- Our **inquiry and analysis** consist in seeking information from knowledgeable persons, both technical and non-technical, which may provide us with details previously not possessed. It may range from **formal written inquiries to informal oral inquiries**. Inquiries were performed during the meetings with relevant persons from the Company.

Areas in scope and their objectives

Physical Security	To determine whether the risk of unauthorized access , theft or destruction of hardware (data theft) and unavailability of systems and applications is properly managed.
Logical Security	To manage the access to programs and data in order to reduce the risk of unauthorized access/loss/alteration of data .
Change Management	To existing systems/applications are authorized, tested, approved, properly implemented and documented in order to manage the risk of alterations of production data and functionalities.
Backup & Continuity	To implement appropriate backup and recovery procedures to ensure that data, transactions and programs can be recovered in case of system failure, environmental hazards, theft of data etc.
IT Operations	To determine whether adequate controls for computer operations have been established to ensure that system/ application processing is appropriately authorized and scheduled and deviations from scheduled processing are identified and resolved.
Service Provider Management	To minimize the risk associated with non-performing suppliers and to ensure business continuity in case of supplier's failure.

Cost and frequency of a data breach by initial attack vector



Figure 7. Measured in USD millions; percentage of all breaches

IBM 2024 Cost of Data Breach Report

Un test de incendiu, cu efecte peste așteptări, a „ars” sâmbătă sistemul informatic al ING-ului. Clienții nu au putut să scoată bani sau să facă operațiuni. Comisioanele de retragere de la alte bănci vor fi returnate. Umorul clienților, de neprețuit: „ING ține la economiile oamenilor, altfel câți bani am fi cheltuit sâmbăta asta dacă am fi putut?”

[Distribuie](#) [Postează](#) [Share](#) [Urmărește](#) [Print](#) [Mail](#)



Autor: [Adelina Mihai](#)

12.09.2016, 00:05 2690

Sâmbătă seara, serviciile ING au început să fie funcționale, iar ieri banca a anunțat cauzele acestui incident.

„Ieri (sâmbătă – n.red.), în timpul unui test planificat al sistemului de stingere a incendiilor din centrul nostru de date, eliberarea gazului Inergen a afectat în

Physical security (1)

Risks

- Unauthorized access to the server rooms;
- Theft or destruction of hardware (data theft).

Description

Accesses to server rooms are protected by the following elements :

- an access control system such as a digital door code, access badges, etc.,
- a video surveillance system, the recordings of which are kept for a sufficient period of time,
- the organization of night patrols by security personnel.

Applicability

Server room

Computer room

Network cabinets

Hardware

How do we audit (general approach)

- Obtain an understanding regarding the existence of policies, norms and procedures for physical security
- Verify the access controls measures adopted by the organization (e.g. secure code, access control system)
- Site inspection
- Obtain the list with all the authorized employees to access the server room/computer room
- Verify if access logs are recorded and maintained for a sufficient period
- Verify what is the access policy for visitors
- Obtain evidence to ensure compliance with visitors' policy

Level of risks - examples

	Access control security measures
STRONG	• Centralized access control system based on nominal access badges and PIN codes available to a limited number of employees obtained only by formal approval of the employee's supervisor • Permanent guard (service provided by a trusted security firm) • Visitors access is permitted only when accompanied by authorized personnel and only on specific hours of the day • Any person entering the server/computer room needs to be registered at entrance using the ID card details and weighted both when he/she enters/leaves the server/computer room • Video surveillance system, the recordings of which are kept for a sufficient period of time and periodically reviewed • The server/computer room has to be located on a separate facility (on basement level or on the ground floor) from the main working facility
MEDIUM	• Decentralized access control system based on nominal access cards available to a limited number of employees obtained only by formal approval of the employee's supervisor • Periodic guard • Visitors access is permitted only when accompanied by authorized personnel • The visitors ID card details are kept on a register
LOW	• Access made using a limited number of keys or only a PIN code • Visitors access permitted only when accompanied by other employee • The server/computer room can be located into the same building

Physical security (2)

Risks

- Destruction of hardware;
- Unavailability of systems and applications

Description

Server rooms are properly equipped in order to prevent damages caused by potential: fire hazards/ floods/ heat excesses/ power outage.

These protection systems are **adequately dimensioned**, effectively protecting the hardware.

Applicability

Server room

Computer room

Network cabinets

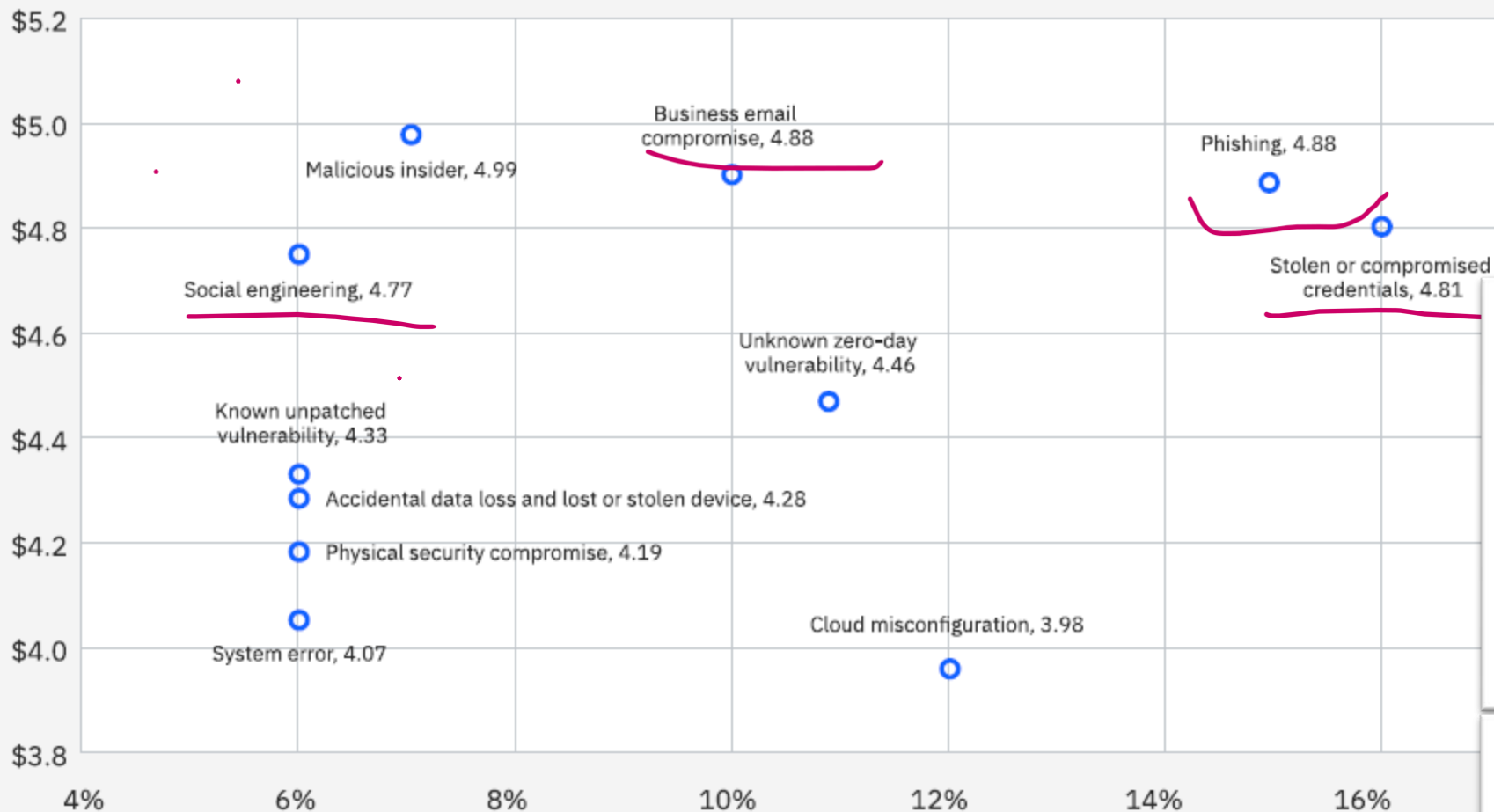
How do we audit (general approach)

- Obtain an understanding regarding the existence of policies, norms and procedures for physical security and environmental protection
- Site inspection:
 - Verify if the monitoring equipment's for the humidity levels, temperature, power etc. indicates any alerting values.
 - Verify if there are fire extinguishers in place and the last revision date.
 - Verify if there are any inflammable pieces of material stored into the server/computer room
 - Verify the last revision date for the UPS power batteries
 - Verify if power generators are in place and if the AAR is functioning normally (AAR ups batteries last inspection date)

Level of risks - examples

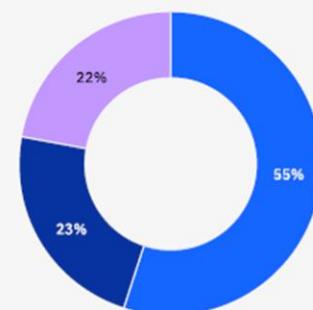
RISK	Mitigating measure
Fire	Air conditioning Temperature monitoring systems Fire extinguishers (Halocarbon Fire extinguishers, Halon 1211 extinguishers, CO2 fire extinguishers) – Not to be used: Water or Foam Extinguishers Inert fire extinguishing system
Earthquake	Earthquake protection system Server room located on first floor
Power outage	Backup generators UPS AAR system („An Automatic Reserve Analogue (AAR) system has the function of maintaining continuity in the power supply of a consumer or of consumers in the event of a power supply main power supply interruption by passing the power supply to a secondary power source.”) Contract with a backup power supplier Permanent monitoring
Floods	Raised floors Water evacuation routes Humidity levels monitoring system
Corrosion	Humidity levels monitoring system

Cost and frequency of a data breach by initial attack vector

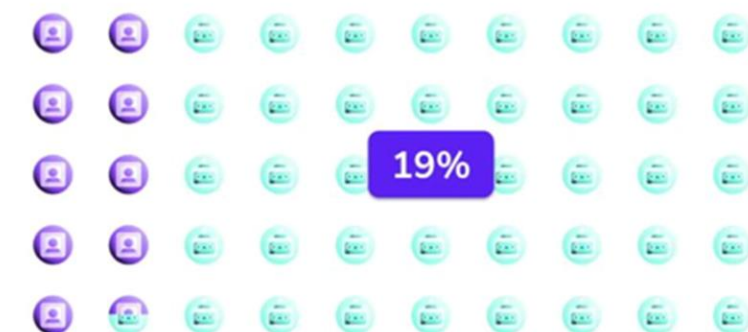


Root cause of the data breach between 3 categories

- Malicious or criminal attacks
- IT failure
- Human error



How Many Identities Are Human?



Identity Attack Surface is Huge....

...and growing



Figure 7. Measured in USD millions; percentage of all breaches

IBM 2024 Cost of Data Breach Report

Logical security (1)

Risks

- Inappropriate or fraudulent accesses to IT resources,
- Fraudulent or unintentional data alteration or entry.

Description

The **management of accesses** to IT resources (creation, modification and deactivation of access rights and / or user accounts) is the subject of a formalized and logged process.

Access rights and / or user accounts requests are **formally approved** before being processed.

Applicability

Operation System

IT systems

Databases

Network access

How do we audit (general approach)

- Obtain an understanding regarding the existence of policies, norms and procedures for access rights management.
- Obtain the HR list with all the employees that joined/left/changed the position within the company taking in scope the audited period
- Request the application user list along with the creation date and, based on the audited period and crosschecks with the HR lists, select a sample of newly created accounts and verify if the access request was approved by the appropriate level of management
- Cross check the user accounts list with the HR list and verify if the terminated user accounts were deactivated in a timely manner.
- Verify if , for changes of position within the company, the proper access rights changes were performed into the systems
- Based on the user accounts list, inspect the last log on date and verify if the user accounts are in use

Level of risks - examples

Situation	Access policy
New employee	User account created based on approval from the supervisor (signed form, email, ticket request) for every application and access right granted based on employee's job position (mapping) Identity Management system
Change of position	Access rights of the employee changed based on formal request from the supervisor (signed form, email, ticket request) Identity Management system
Terminated account	User account terminated based on liquidation note User account terminated based on specific number of days of inactivity Identity Management system

Logical security (2)

Risks

Fraudulent or unintentional data alteration or entry

Description

The segregation of duties principles are documented within a matrix and are implemented within the systems.

The segregation of duties matrix is periodically reviewed in order:

- to ensure its compliance with best practices,
- to assess the alignment of these principles with the company's operational reality.

Applicability

IT Systems

Applications/ Databases

Network access

How do we audit (general approach)

- Obtain an understanding regarding the segregation of duties principle implementation into the system
- Perform selective interviews with employees in order to gain an understanding of their use of application
- Conclude if the segregation of duties matrix is in line with the job responsibilities based on interviews
- Obtain evidence of the last review of the segregation of duties matrix
- Based on the list with the user accounts rights defined into the system verify if the segregation of duties matrix is implemented accordingly

Logical security (3)

Risks

- Fraudulent or unintentional data alteration or entry;
- Inappropriate or fraudulent accesses to IT resources.

Description

The security settings regarding the **passwords** are compliant with best practices.

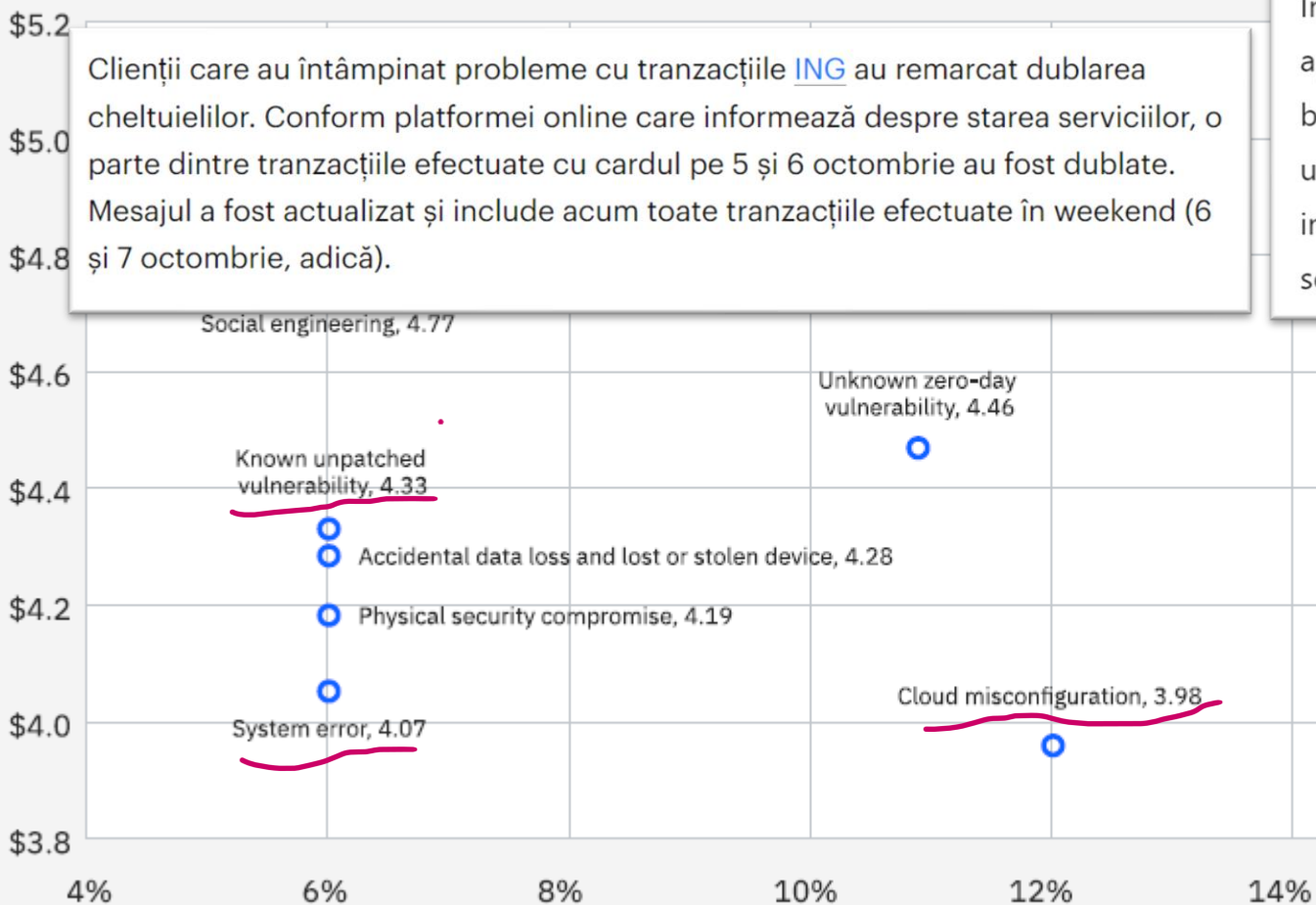
Applicability

Operating systems
Applications/ Databases
Network access

How do we audit (general approach)

- Obtain the security policy and verify the password security requirements
- Extract from the system the password security settings
- Verify the password security settings against the password security requirements defined into the security policy

Cost and frequency of a data breach by initial attack vector



Case Study: Capital One Data Breach (2019):

In July 2019, Capital One experienced a significant data breach affecting approximately 100 million customers in the U.S. and 6 million in Canada. The breach was attributed to a misconfigured web application firewall, which allowed unauthorized access to sensitive data. This misconfiguration highlights the critical importance of effective change and release management processes to ensure that security settings are correctly implemented and maintained. MIT CAMS

Root cause of the data breach between 3 categories

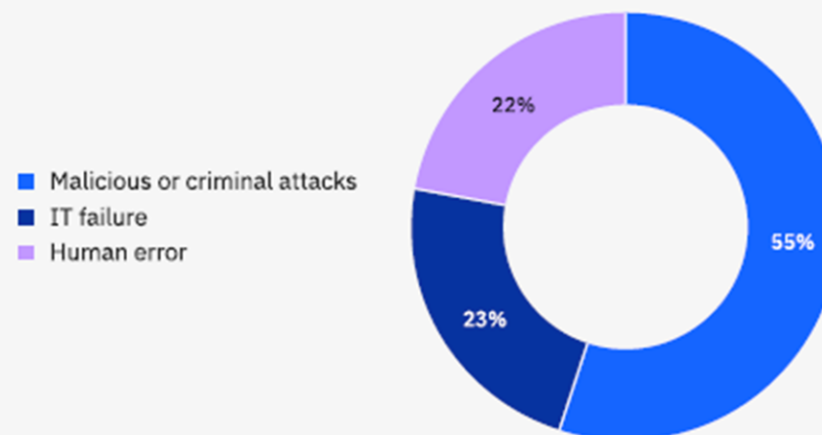


Figure 7. Measured in USD millions; percentage of all breaches

Change management (1)

Risks

Implementation of developments containing bugs or not matching the business' requirements.

Description

Before their implementation within systems, changes are subject to the following the tests:

- unitary tests,
- functional validation tests,
- non-regression tests,
- integration tests,
- user acceptance tests (UAT).

The scripts and results of the tests are documented by the employee in charge of the testing. The follow-up on tests relies on a dedicated tool, allowing to trace the validations at each step of the testing process.

Applicability

IT systems
Applications/ Databases

How do we audit (general approach)

- Obtain an understanding regarding the Change Management process defined into the company
- To obtain the list of changes applied (CLOSED) to the system in scope
For a sample of changes applied to the system for the audited period in scope verify if evidence of appropriate testing is in place (e.g. UAT)
- Verify that these tests are adequately and sufficiently documented (key user, test scripts in place, tests results, conclusion) and that the testing results are subject to a formal approval.

Change management (2)

Risks

Implementation of regression in the production environment, inducing bugs, losses or alterations of production data and functionalities.

Description

Distinct computing environments exist within the company to develop and test changes before deployment in production.

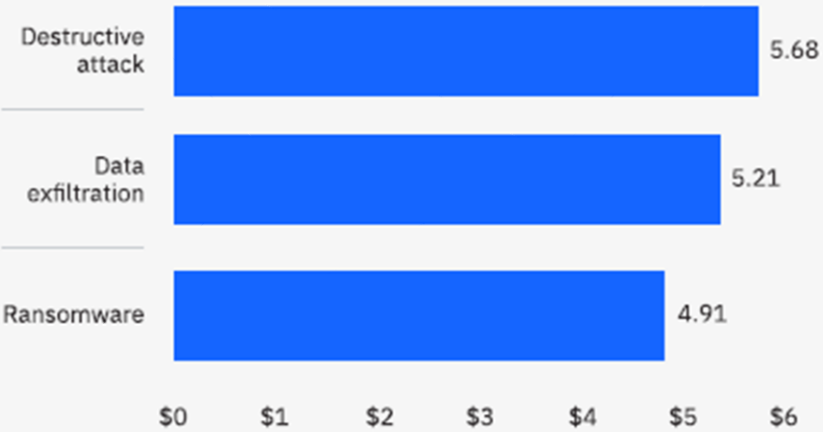
Applicability

IT systems
Databases

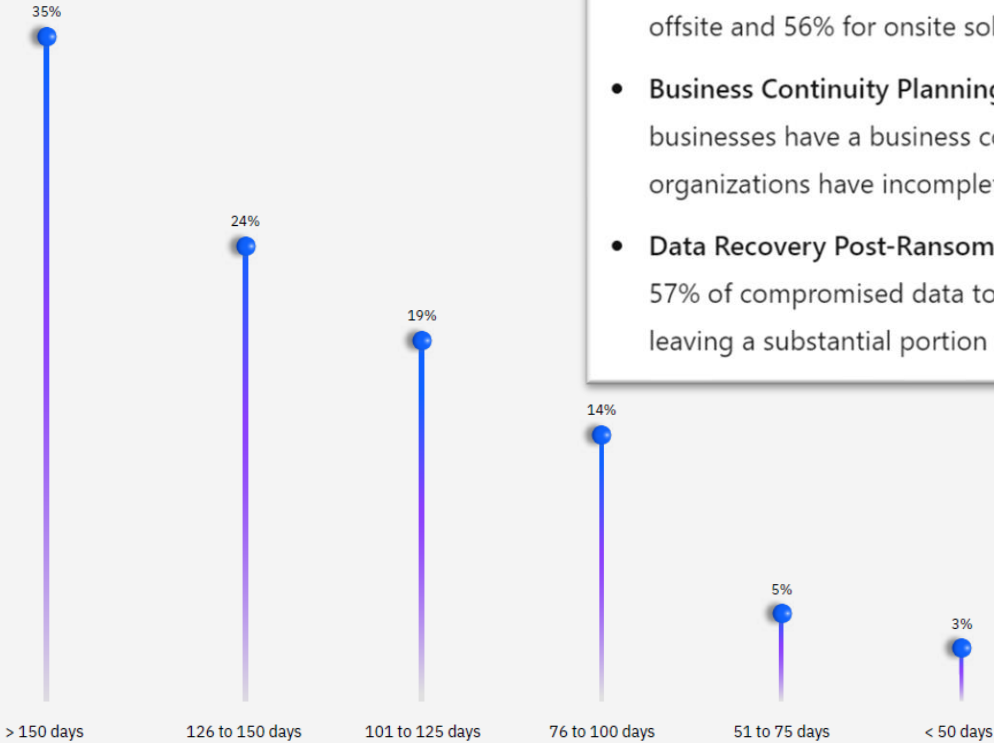
How do we audit (general approach)

- Obtain an understanding regarding the change management process defined and request the Change Management Procedure.
- For the in scope systems, verify if there are separate testing, production and development environments.
- Check if distinct hardware environment exists for production/testing environments

Cost of a data breach for 3 types of extortion attacks



Average time to recover from a data breach



- **Backup Failures:** Despite 92% of businesses reporting having backups, 31% fail to restore data during ransomware attacks. Notably, cloud backups demonstrate a higher recovery success rate of 80%, compared to 55% for offsite and 56% for onsite solutions. AT-BAY
- **Business Continuity Planning:** A global survey revealed that 61% of businesses have a business continuity plan. However, nearly 20% of U.S. organizations have incomplete plans, and 14% lack any plan at all. INVENIO IT
- **Data Recovery Post-Ransomware:** On average, organizations can expect on 57% of compromised data to be recovered following a ransomware attack, leaving a substantial portion of data unrecoverable. THE JOURNAL

Case Study: Indonesian Government Data Breach (2024):

In June 2024, the Indonesian government suffered a significant ransomware attack affecting over 230 public agencies, including critical services like immigration and airport operations. Investigations revealed that 98% of the data in one compromised data center had not been backed up due to governance issues and budget constraints. This lack of adequate backups severely hindered recovery efforts and prompted a nationwide audit of data centers to address these deficiencies. REUTERS

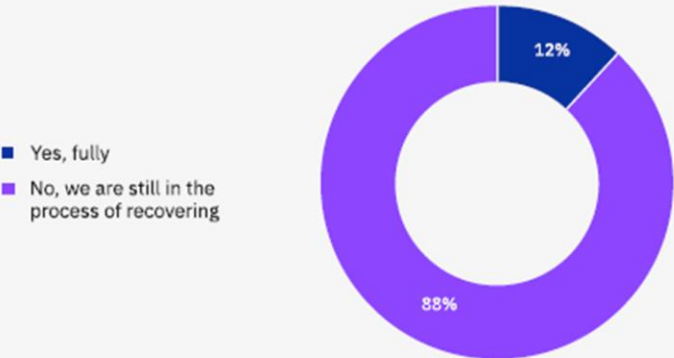
63%

Share of ransomware victims that involved law enforcement and avoided paying a ransom.

Time to identify and contain 3 types of extortion attacks
All 3 types of attacks required between 284 and 294 days to identify and contain. See Figure 31.

Paying the ransom
When organizations fell victim to ransomware, 52% called in law enforcement. The majority of those that did, 63%, ended up not paying the ransom. See Figure 32.

Has your organization recovered from the data breach?



Backup and continuity (1)

Risk

- Partial or complete loss of data;
- Loss of the traceability of backup incidents and of the audit trail.

Description

Incidents related to the execution of automated backup processes are consigned and timely resolved with respect to the business' requirements.

Applicability

IT systems
Databases
Operating systems

How do we audit (general approach)

- Obtain the backup management procedure
- Verify that the document specifies the roles and responsibilities, as well as the actions to be taken in case of backup incidents
- Obtain the backup logs recorded on the audit period
- On the basis of a sample, collect the corresponding incident declaration form and verify its timely resolution

Backup and continuity (2)

Risk

- Partial or complete loss of data;
- Incoherence of the content of the backups with the business requirements.

Description

Backups are subject to periodic restoration tests in order to ensure:

- the viability of the backup media;
- the technical ability of the teams to perform the restoration operations.

Applicability

IT systems

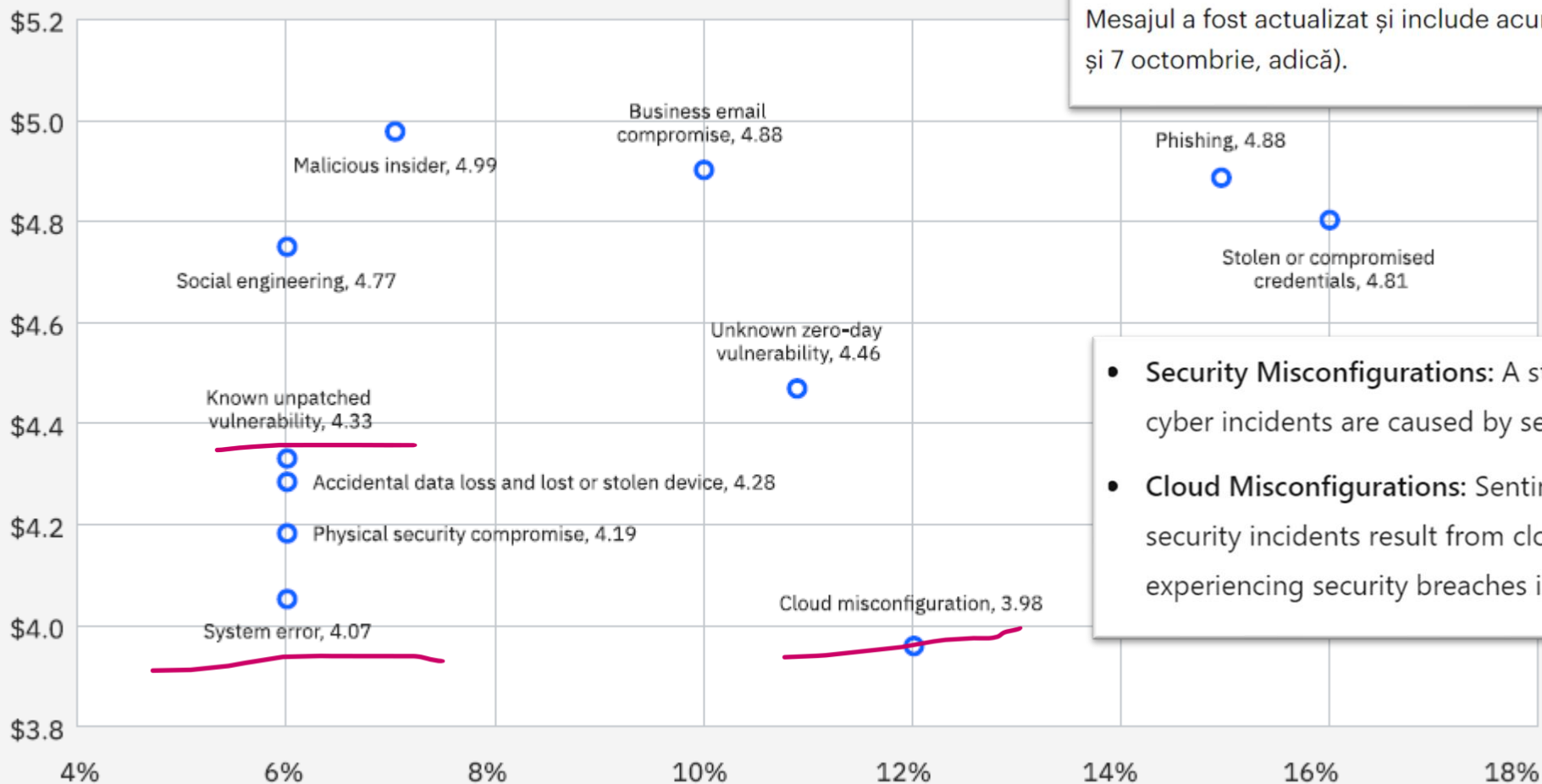
Databases

Operating systems

How do we audit (general approach)

- Enquire if restorations have been needed and performed on the audit period.
- Analyze the backup procedure to verify that data restoration is properly addressed.
- Verify that key reports such as trial balances, GL balances, HR number of records, or operational reports are generated before each restoration and compared to the same reports after restoration, before being approved by appropriate business staff.
- Collect a sample of restoration test reports and verify if the testing scenario, the results obtained and the action plans in case of noted deficiencies are documented.

Cost and frequency of a data breach by initial attack vector



Clienții care au întâmpinat probleme cu tranzacțiile [ING](#) au remarcat dublarea cheltuielilor. Conform platformei online care informează despre starea serviciilor, o parte dintre tranzacțiile efectuate cu cardul pe 5 și 6 octombrie au fost dublate. Mesajul a fost actualizat și include acum toate tranzacțiile efectuate în weekend (6 și 7 octombrie, adică).

- **Security Misconfigurations:** A study by SOCRadar revealed that 35% of all cyber incidents are caused by security misconfigurations. SOCRADAR
- **Cloud Misconfigurations:** SentinelOne reported that nearly 23% of cloud security incidents result from cloud misconfigurations, with 27% of businesses experiencing security breaches in their public cloud infrastructure. SENTINELONE

Figure 7. Measured in USD millions; percentage of all breaches

IT operations (1)

Risk

Implementation of fraudulent automated processes.

Description

The automated processes (either jobs, batches, interfaces or processing) are administered and monitored using dedicated scheduling tools. The access to these tools is restricted to a limited number of members of the IT teams.

Applicability

IT systems
Databases

How do we audit (general approach)

- Obtain a data flow diagram outlining the transfer of information
- Using inquiry identify significant data flows between IT systems
- Collect evidence of the existence of a scheduling and monitoring tool. (e.g. print screen)
- Verify that security aspects are specified by the automated process management procedure.
- Collect the extract of users with accesses to the scheduler.
- Verify that the list of these users is limited and restricted to the appropriate employees in regard to their function within the company.

IT operations (2)

Risk

- Instability of systems;
- Loss of the exhaustiveness or of the integrity of data.

Description

An incident management process exists and relies on a dedicated tool. This process is the subject of a procedure which specifies at least the following:

- the roles and responsibilities within the process,
- the impact and urgency criteria, as well as the resolution targets depending on the level of priority attributed to the incident,
- the process and levels of escalation.

Applicability

Norms and procedures

How do we audit (general approach)

- Obtain the incident management procedure and verify that it was formally approved and that it contains:
 - the roles and responsibilities within the process
 - the impact and urgency criteria
 - resolution targets depending on the level of priority attributed to the incident
 - the process and levels of escalation
- Obtain the Service Level Agreement
- Verify if periodic reports exists to check the service level adherence
- Collect the extract of incidents opened on the audit period from incident management tool/tools
- On a sample basis verify compliance of incidents with current procedure (timeframes, roles and responsibilities)

- **Prevalence of Third-Party Breaches:** A 2024 study revealed that 61% of organizations experienced a third-party data breach or security incident within the past 12 months, marking a 49% increase from the previous year and a threefold rise since 2021. PREVALENT
- **Widespread Impact:** Research indicates that 98% of organizations maintain relationships with third parties that have suffered breaches, highlighting the extensive reach of third-party vulnerabilities. SECUREFRAME
- **Significant Disruptions:** Approximately 73% of organizations reported experiencing at least one major disruption due to a third-party cyber incident in the past three years, emphasizing the operational risks associated with insufficient vendor oversight. BITSIGHT

Case Study: AT&T Data Breach (2023):

In January 2023, AT&T faced a data breach affecting 8.9 million wireless customers. The incident involved a third-party vendor's failure to delete outdated customer data from 2015 to 2017, leading to unauthorized exposure of account information. In response, AT&T agreed to a \$13 million settlement and committed to enhancing its data governance and vendor management practices.

REUTERS

Service provider management (1)

Risk

- Inability to guarantee the availability of the Information System;
- Inability to properly evaluate the quality of the service delivered;
- Dependency on the service providers.

Description

Services supplied by providers are subject to **contractual agreements**.

Applicability

IT Systems
Databases
Network
Operations
Hardware

How do we audit (general approach)

- Identify the service providers considered to be critical, i.e. which may significantly impact the company's activity.
- Collect the contracts signed between the company and these third parties.
- Verify that for the maintenance of each applications which cannot be performed by the IT teams of the company, a service provider has been identified, and that a written agreement for the assistance of the company has been signed.
- Review the contractual clauses to verify their alignment with the current best practices.
- Verify that the Service Level Agreements of each contract are up to date.

Service provider management (2)

Risk

Lack of internal control related to continuity of services by the service provider which could impact the company's activity

Description

For sensitive externalized services, the company disposes of **guarantees regarding the internal control environment related to continuity of service.**

Applicability

IT Systems
Databases
Network
Operations
Hardware

How do we audit (general approach)

- Obtain the list of critical externalized services
- For a sample of these services , request the contractual and SLA agreements
- Verify if the contractual agreements contain provisions regarding business continuity, agreed RTO and RPO for the externalized service and requirements of BCM tests
- Request and verify if the evidence of the supplier's BCM&DR process testing or valid certification (like ISO27001, ISO22301)

How to audit

ISO 27001



ISO 27000 series

- ISO/IEC 27001 — Information technology - Security Techniques - **Information security management systems — Requirements**. The 2013 release of the standard specifies an information security management system in the same formalized, structured and succinct manner as other ISO standards specify other kinds of management systems.
- ISO/IEC 27002 — **Code of practice for information security controls** - essentially a detailed catalogue of information security controls that might be managed through the ISMS
- ISO/IEC 27003 — Information security management system **implementation guidance**
- ISO/IEC 27004 — Information security management — **Monitoring, measurement, analysis and evaluation**
- ISO/IEC 27005 — Information security **risk management**
- ISO/IEC 27007 — Guidelines for information security management systems **auditing** (focused on auditing the management system)
- ISO/IEC TR 27008 — **Guidance for auditors** on ISMS controls (focused on auditing the information security controls)

ISO 27001

- **ISO/IEC 27001** formally specifies an **Information Security Management System (ISMS)**, a suite of activities concerning the management of information risks
- While **ISO/ IEC 27001** does not formally mandate specific **information security controls** (since the controls that are required vary markedly across the wide range of organizations adopting the standard), **ISO 27002** includes such a list in the appendix of the standard

ISO 27002

- **ISO/IEC 27002** is a popular, internationally-recognized standard of **good practice** for information security. It recommends **information security controls** addressing information security control objectives arising from risks to the **confidentiality, integrity** and **availability** of information.

ISO 27001

Appendix A

2013 version

A.5 Security Policies

A.6 Organisation of information security

A.7 Human resource security

A.8 Asset management

A.9 Access control

A.10 Cryptography

A.11 Physical and environmental security

A.12 Operations security

A.13 Communications security

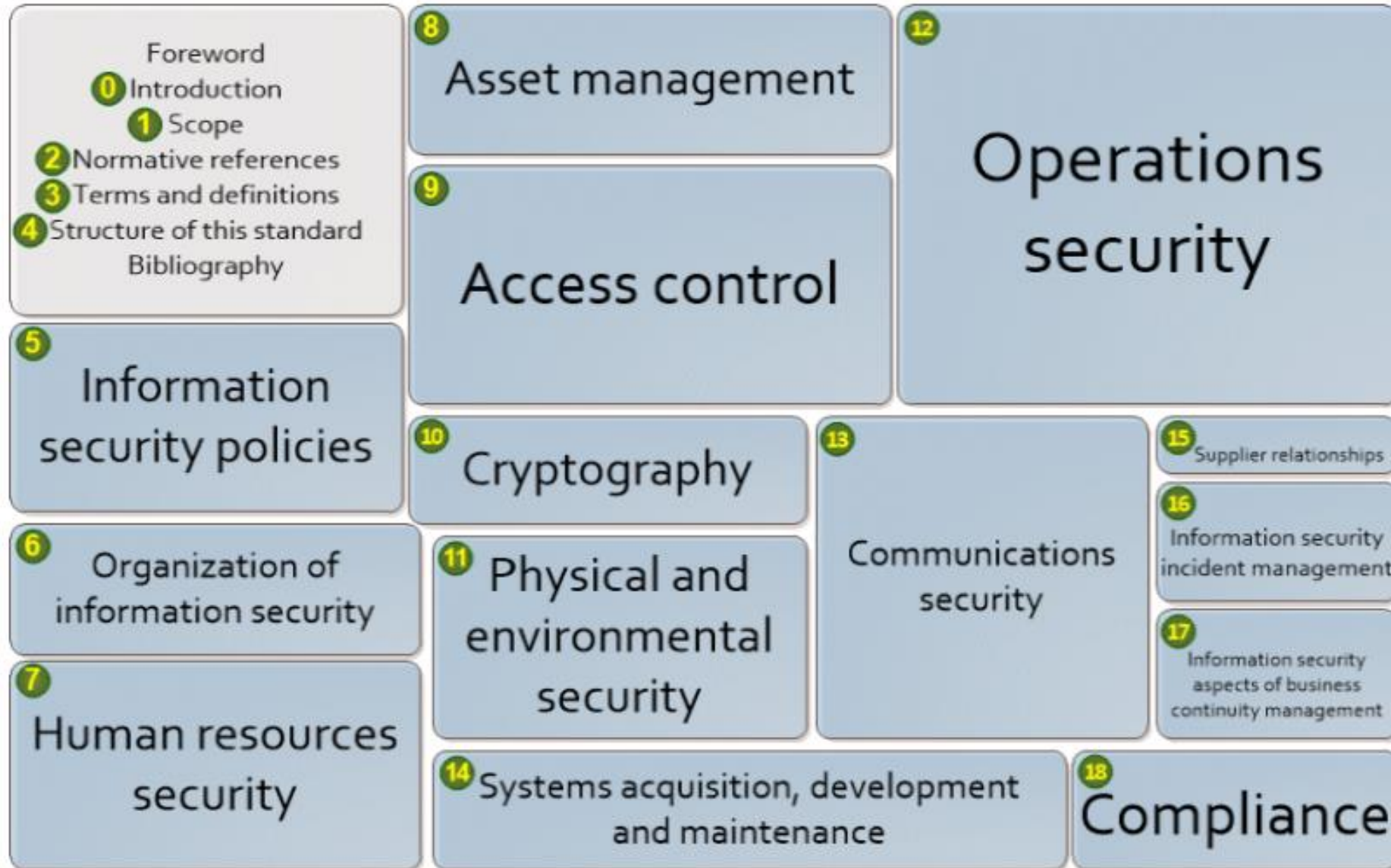
A.14 System acquisition, development and maintenance

A.15 Supplier relationships

A.16 Information security incident management

A.17 Information security aspects of business continuity management

A.18 Compliance



Source: <https://www.iso27001security.com/>

Access management

Risk: Inappropriate or fraudulent accesses to IT resources,

Description:

The management of accesses to IT resources (creation, modification and deactivation of access rights and / or user accounts) is the subject of a formalized and logged process. Access rights and / or user accounts requests are formally approved before being processed.

Applicability:

Operation System
IT systems
Applications/ Databases
Network access

How do we audit (general approach)

- ✓ Obtain an understanding regarding the existence of policies, norms and procedures for access rights management.
- ✓ Obtain the HR list with all the employees that joined/left/changed the position within the company taking in scope the audited period
- ✓ Request the application user list along with the creation date and, based on the audited period and crosschecks with the HR lists, select a sample of newly created accounts and verify if the access request was approved by the appropriate level of management
- ✓ Cross check the user accounts list with the HR list and verify if the terminated user accounts were deactivated in a timely manner.
- ✓ Verify if , for changes of position within the company, the proper access rights changes were performed into the systems
- ✓ Based on the user accounts list, inspect the last log on date and verify if the user accounts are in use

Access Control

Section 9: Access control

9.1 Business requirements of access control

The organization's requirements to control access to information assets should be clearly documented in an **access control policy and procedures**. Network access and connections should be restricted.

9.2 User access management

The allocation of **access rights** to users should be controlled from initial user registration through to removal of access rights when no longer required, including **special restrictions** for **privileged access rights** and the **management of passwords** (now called "secret authentication information") plus regular reviews and updates of access rights.

9.3 User responsibilities

Users should be made aware of their **responsibilities** towards maintaining effective **access controls** e.g. choosing **strong passwords** and keeping them confidential.

9.4 System and application access control

Information access should be restricted in accordance with the **access control policy** e.g. through **secure log-on, password management, control over privileged utilities and restricted access to program source code**.

How to audit

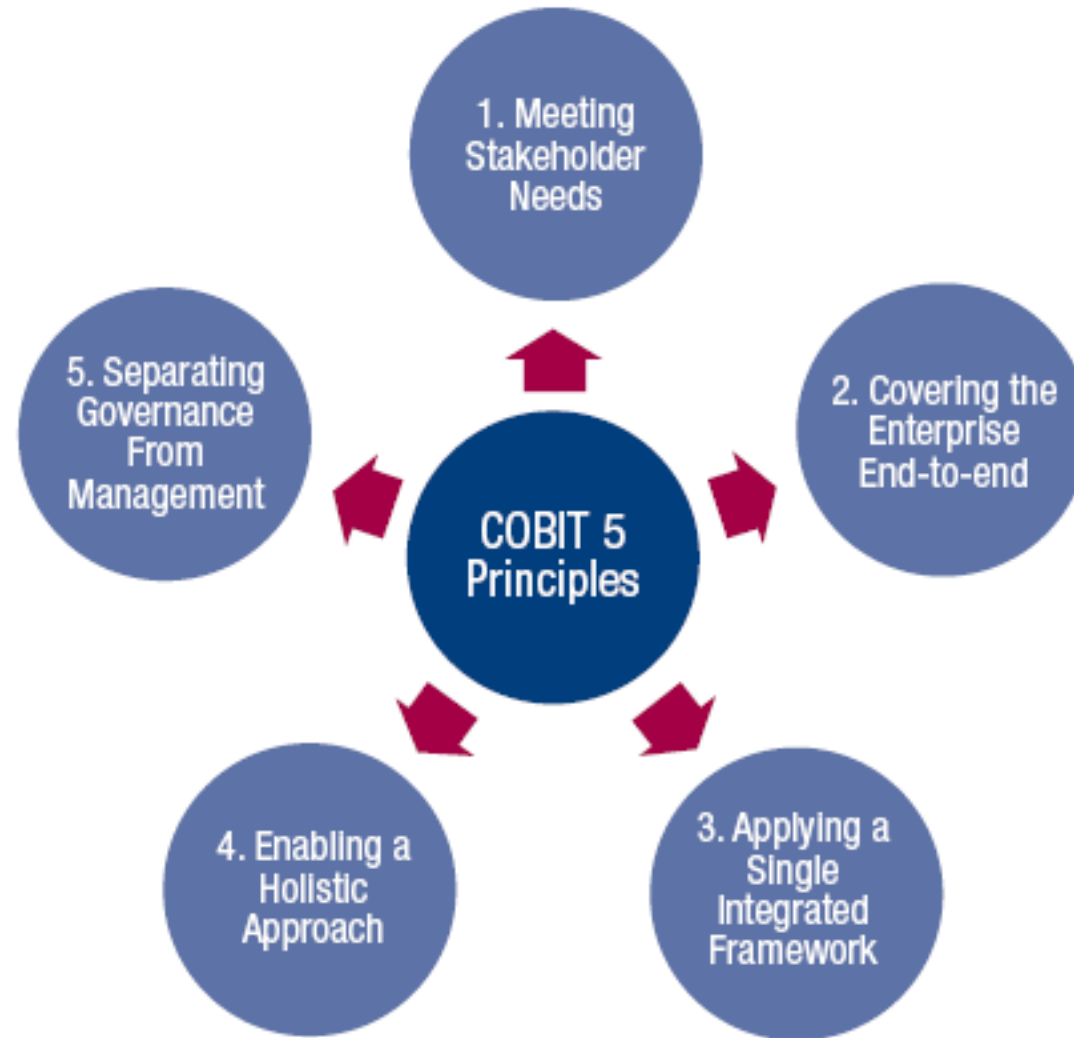
COBIT 5



COBIT

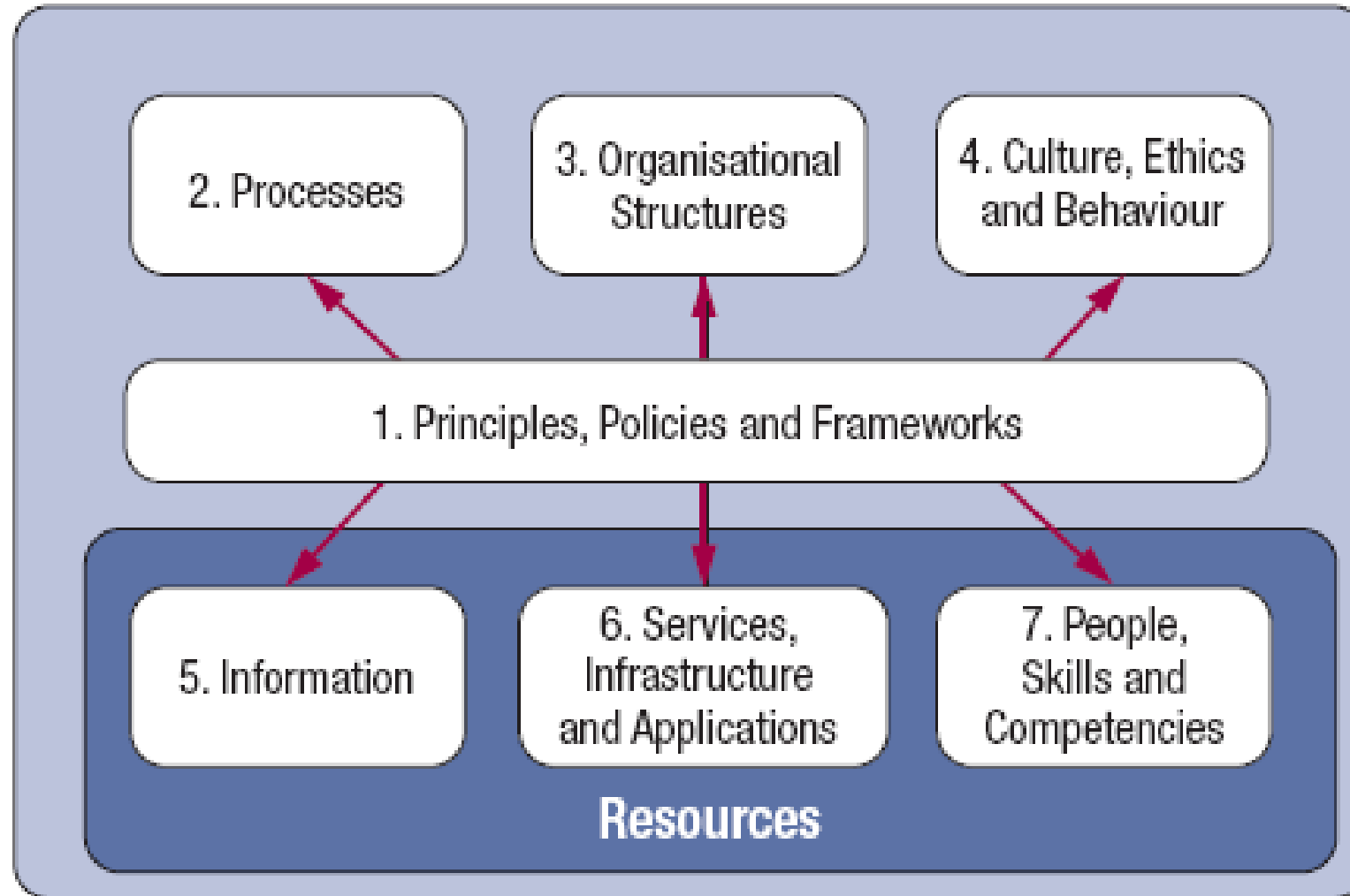
- COBIT 5 is the only business framework for the governance and management of enterprise IT. It is the product of a global task force and development team from ISACA.
- COBIT 5 incorporates the latest thinking in enterprise governance and management techniques, and provides globally accepted principles, practices, analytical tools and models to help increase the trust in, and value from, information systems.
- COBIT 5 builds and expands on COBIT 4.1 by integrating other major frameworks, standards and resources, including ISACA's Val IT and Risk IT, Information Technology Infrastructure Library (ITIL®) and related standards from the International Organization for Standardization (ISO).
- COBIT 5 is used globally by those who have the primary responsibility for business processes and technology, depend on technology for relevant and reliable information, and provide quality, reliability and control of information and related technology.

COBIT 5 principles



Source: ISACA COBIT5 Toolkit 2019

COBIT 5 enablers



Source: ISACA COBIT5 Toolkit 2019

Processes for Governance of Enterprise IT

Evaluate, Direct and Monitor

EDM01 Ensure Governance Framework Setting and Maintenance

EDM02 Ensure Benefits Delivery

EDM03 Ensure Risk Optimisation

EDM04 Ensure Resource Optimisation

EDM05 Ensure Stakeholder Transparency

Align, Plan and Organise

AP001 Manage the IT Management Framework

AP002 Manage Strategy

AP003 Manage Enterprise Architecture

AP004 Manage Innovation

AP005 Manage Portfolio

AP006 Manage Budget and Costs

AP007 Manage Human Resources

AP008 Manage Relationships

AP009 Manage Service Agreements

AP010 Manage Suppliers

AP011 Manage Quality

AP012 Manage Risk

AP013 Manage Security

Build, Acquire and Implement

BAI01 Manage Programmes and Projects

BAI02 Manage Requirements Definition

BAI03 Manage Solutions Identification and Build

BAI04 Manage Availability and Capacity

BAI05 Manage Organisational Change Enablement

BAI06 Manage Changes

BAI07 Manage Change Acceptance and Transitioning

BAI08 Manage Knowledge

BAI09 Manage Assets

BAI10 Manage Configuration

Deliver, Service and Support

DSS01 Manage Operations

DSS02 Manage Service Requests and Incidents

DSS03 Manage Problems

DSS04 Manage Continuity

DSS05 Manage Security Services

DSS06 Manage Business Process Controls

Monitor, Evaluate and Assess

MEA01 Monitor, Evaluate and Assess Performance and Conformance

MEA02 Monitor, Evaluate and Assess the System of Internal Control

MEA03 Monitor, Evaluate and Assess Compliance With External Requirements

Processes for Management of Enterprise IT



Source: ISACA COBIT5 Toolkit 2019

Compliance with legal requirements

Certain industries, such as banks and internet service providers (ISPs), are closely regulated. These legal regulations may pertain to financial, operational and IS audit functions.

Popular local legal requirements:

- Internet banking (MCSI)
- Electronic archiving (MCSI)
- SEP (BNR)
- Norma 4 (ASF)

How to audit

Internet Banking



Local legal requirements

(1) Internet Banking

The MCSI Order no. 553/ 05.06.2019 includes:

- details on the **procedure for obtaining MCSI confirmation** on the electronic payment systems (internet-banking, home-banking, phone-banking sau mobile-banking).
- **list of minimum security requirements** needed to be met by the electronic payment systems
- requirement of **annual risk evaluation exercises** for the areas in scope – operational risks arising from usage of the systems in scope
- requirements of **annual penetration tests** for the software applications and information systems used related to the payment systems.
- requirements on **verifications of the prior year results** (recommendations and action plans agreed)
- **details on the audit report content**
- List of certifications accepted by MCSI for the pentest team (CEPT, CPT, GPEN, GWAPT, LPT, OPST, OSCE, OSCP, PTC)
- List of certifications accepted by MCSI for the audit team (CISA, GSNA, GCCC, CISSP)

Local legal requirements

(2) Internet Banking

Cerinte minime de securitate [extras din Ordin nr 553 din 5 iunie 2019]:

1. **confidențialitatea și integritatea comunicațiilor între emitent și beneficiarul instrumentului financiar de plată electronică cu acces la distanță;**
2. *mecanismele care să **garanteze** confidențialitatea și nerepudierea operațiunilor efectuate utilizând instrumentul de plată electronică cu acces la distanță;*
3. **autenticitatea părților care participă la tranzacții și existența metodelor de autentificare** în concordanță cu nivelul de securitate al platformei software, precum și mijloacele de garantare a identității;
4. **confidențialitatea, autenticitatea și integritatea informațiilor/datelor** aferente tranzacțiilor efectuate cu ajutorul instrumentului de plată electronică, prin sistemul informatic al emitentului, în timpul **procesării, stocării și arhivării acestora;**
5. *păstrarea **secretului bancar;***
6. **trasabilitatea tranzacțiilor;**
7. *respectarea **protecției datelor cu caracter personal** în sistemele informatice;*
8. **controlul accesului fizic și logic la sistemul informatic și la platforma/aplicația software** utilizate în procesul de furnizare a instrumentului financiar de plată electronică cu acces la distanță;
9. **stocarea, păstrarea datelor înregistrate și jurnalizarea acestora, precum și păstrarea în siguranță a unor copii de rezervă ale datelor și aplicațiilor;**

Local legal
requirements

(3) Internet Banking

[Continuare]

10. **prevenirea/limitarea/înlăturarea impactului incidentelor de securitate informatică**, reluarea în siguranță a activității și recuperarea informațiilor afectate;
11. **detectarea, înregistrarea și gestionarea incidentelor de securitate informatică**;
12. **evaluarea riscurilor de securitate informatică și măsuri de gestionare a acestora**;
13. **asigurarea unui proces formal și continuu (cel puțin anual) de pregătire a resurselor umane implicate în operarea, mentenanța și administrarea instrumentelor de plată electronică cu acces la distanță și o evaluare anuală a acestora**;
14. **continuitatea serviciilor** oferite clienților;
15. **gestionarea și administrarea sistemului informatic**;
16. **impactul operațiilor de modificare a:**
 - a) **arhitecturii** din cadrul sistemului informatic (componente hardware/software) și aplicațiilor software utilizate în ciclul de viață al instrumentului de plată electronică cu acces la distanță; și
 - b) **planului de securitate** specific securității aferente instrumentului de plată cu acces la distanță;
17. **orice alte activități** sau măsuri tehnice întreprinse pentru exploatarea în siguranță a sistemului informatic al emitentului.

How to audit

Electronic archiving



Local legal
requirements

(1) Electronic
archiving

- Law no. 135/ 15.05.2007 includes requirements for **design, storage, consultation and usage of the electronic documents, or, documents which will be in the scope of electronic archiving.**
- MCSI Order no. 493/ 15.06.2009 includes the **guidance for applying electronic archiving law**
- MCSI Order no. 489/ 15.06.2009 includes the guidance for **data center authorization** (additional requirements have been included in the MCSI Order no. 585/ 09.05.2011 and no. 1167/ 25.11.2011)

Local legal
requirements

(2) Electronic
archiving

- For data center authorization an **audit** should be performed **once in 3 years**
- The report together with the entire documentation as per the legislation need to be submitted to MCSI for (re)authorization
- Technical requirements are included both in law no. 135 and Order no. 489.

Local legal requirements

(3) Electronic archiving

Extract from legislation (**Law 135**) on the technical requirements for data center authorization:

Arhivele electronice sunt depozitate în centre de date supuse autorizării prealabile, cu respectarea normelor privind asigurarea:

- ***integrității și securității*** documentelor în formă electronică;
- ***securității și integrității spațiului ocupat*** de echipamentele care găzduiesc arhivele electronice;
- ***recuperării informației*** în urma dezastrelor naturale, conform reglementărilor în vigoare.

Local legal requirements

(4) Electronic archiving

Extract from legislation (**Ordin 489**) on the technical requirements for data center authorization:

- **Art. 3** - Centrele de date utilizate de către administratorii de arhive electronice trebuie să dispună de dotările tehnice și să aplice **politicile și procedurile de management și de securitate** necesare pentru a îndeplini condițiile prevăzute la art. 17 alin. (1) din Legea nr. 135/2007
- **Art. 6** – [...] obiectivele principale urmărite de MCSI [...] **a) asigurarea securității și integrității datelor**, la nivel de **securitate fizică** și acces prin mijloace informatice; **b) disponibilitatea** serviciului de arhivare electronică și **backup-ul informațiilor stocate**.
- **Art. 8** - Spațiul în care funcționează centrul de date trebuie să fie amenajat astfel încât să fie posibilă respectarea cerințelor de securitate specifice și să asigure **funcționarea echipamentelor la parametrii optimi prevăzuți de producătorii acestora**: **a)** instalarea unor sisteme de climatizare care să asigure valorile optime de temperatură și umiditate în vederea funcționării echipamentelor în condiții de siguranță; **b)** utilizarea de materiale ignifuge și instalarea unor sisteme de prevenire și stingere a incendiilor, concepute special pentru evitarea deteriorării echipamentelor; **c)** dimensionarea corespunzătoare a rețelei electrice, în funcție de consumurile echipamentelor folosite; **d)** garantarea siguranței la defecțiunile previzibile ale sistemelor de utilități (apă, gaze etc.) care deservesc spațiul care găzduiește centrul de date.

Local legal requirements

(5) Electronic archiving

Extract from legislation (**Ordin 489**) on the technical requirements for data center authorization:

- **Art. 9** - Asigurarea **redundanței** și **realizarea backup-ului** trebuie să fie implementate prin următoarele măsuri: **a)** utilizarea de **dispozitive UPS** și/sau generatoare electrice, care să asigure funcționarea neîntreruptă a echipamentelor în cazul opririi alimentării cu curent electric de la rețeaua principală; timpul de asigurare a alimentării din sursa de urgență va fi calculat în funcție de timpii estimați pentru remedierea posibilelor avarii care ar surveni la rețeaua electrică principală; **b)** **duplicarea** tuturor elementelor rețelei electrice și asigurarea posibilității comutării automate de pe rețeaua principală pe rețeaua de rezervă; **c)** utilizarea procedurilor de lucru care să asigure efectuarea de **backup periodic** al tuturor informațiilor păstrate în centrul de date și stocarea acestora în alt spațiu, diferit de spațiul principal al centrului de date, cu asigurarea acelorași condiții de securitate ca și cele ale spațiului principal, aflate la o distanță față de spațiul principal care să corespundă normelor europene în domeniu; **d)** asigurarea unor **proceduri de mentenanță** pentru echipamente și pentru infrastructură, respectând recomandările producătorilor echipamentelor respective, astfel încât să se minimizeze riscul apariției de probleme tehnice; **e)** **în cazul echipamentelor critice** (a căror funcționare permanentă este esențială în asigurarea continuității funcționării centrului de date) se vor asigura **echipamente de rezervă**, care vor fi folosite pe perioada efectuării operațiunilor de mentenanță ce implică oprirea sau deconectarea respectivului echipament și pe perioada în care echipamentul principal este afectat de defecțiuni tehnice.
- **Art. 10** - Centrul de date trebuie să aibă o **structură scalabilă**, atât în ceea ce privește echipamentele informatice utilizate, cât și infrastructura, cu scopul de a păstra performanțele sistemului la un nivel constant în cazul apariției de condiții noi (mărirea capacității centrului de date, facilități noi etc).

Local legal requirements

(6) Electronic archiving

Extract from legislation (**Ordin 489**) on the technical requirements for data center authorization:

- **Art. 11 - (1)** Centrul de date trebuie să asigure **securitatea și integritatea** informațiilor stocate atât în ceea ce privește **accesul fizic** la echipamentele utilizate, cât și **accesul prin mijloace electronice** la documentele arhivate.
- **(2)** Securitatea fizică presupune luarea următoarelor măsuri: **a) acces controlat la echipamentele centrului de date** utilizate pentru arhivarea electronică a documentelor, cu precizarea mai multor niveluri de drepturi de acces ale personalului care operează sistemele; **b) utilizarea echipamentelor speciale de evitare și detecție a intruziunilor fizice.**
- **(3)** Pentru asigurarea securității **accesului prin mijloace electronice** la documentele arhivate, trebuie utilizate următoarele măsuri tehnice: **a) sisteme de detecție a intruziunilor** (Intrusion Detection System - IDS); **b) firewall** (software și/sau hardware), routere pentru filtrarea traficului; **c) sisteme antivirus; d) securizarea proceselor de autentificare și de autorizare a accesului** la date; **e) jurnalizarea** automată a acțiunilor efectuate în sistem.

Local legal
requirements

(7) Electronic
archiving

Extract from legislation (**Ordin 489**) on the technical requirements for data center authorization:

- **Art. 12** - Operarea centrului de date trebuie realizată respectându-se **strategii, politici și proceduri** bine determinate în ceea ce privește **managementul, controlul și securitatea sistemelor**. În realizarea acestor politici și proceduri se vor respecta următoarele cerințe minimale: **a) jurnalizarea** cronologică a acțiunilor efectuate în sistem (accesul fizic la echipamente, comutări de pe un sistem pe altul, procese de mentenanță, acțiuni ale operatorului etc); **b) evaluarea** la intervale regulate a infrastructurii centrului de date, a sistemului de securitate și a echipamentelor informatice folosite, inclusiv a sistemelor de backup; **c) folosirea unui sistem de management al calității**; **d) evaluarea efectelor extinderilor și upgrade-urilor**; **e) realizarea auditului regulat al planului de securitate**; **f) evaluarea și perfecționarea periodică a personalului**; **g) implementarea unor politici de resurse umane** care să asigure operarea centrului de date de către personal specializat care să dispună de certificări în domeniu.

How to audit

Norma 4



Local requirements

(1) Norma 4, ASF

Norma 4/2018 – operational risk management related to information systems used by entities authorized/ regulatedd and or supervised by Funancial Supervisory Authority (ASF)

Scope: Identification, prevention and minimization of potential negative impact of operational risks associated to usage of information technology and communication including people, processes, systems and anything else which would relates to information criminality.

Applicability: all relevant systems used by in scope entities (including hardware and software) - exhaustive list included

Risk assessment: mandatory required on a yearly basis; remediation actions and close monitoring required

Entities risk classification is ensured by ASF; a list with required activities included per risk category

Requirements for **third party suppliers** responsible for externalized services

Description of **activities** to be ensured by entities in scope (see next slide)

Description of the required aspects on **testing and auditing** relevant systems

Local requirements

(2) Norma 4, ASF

Activities

- **Yearly vulnerabilities scanning** (depending on the risk classification)
- **Internal/ external penetration testing** (applications, operating systems, infrastructure) & social engineering testing
- **Requirements** for relevant systems:
 - Integrity, confidentiality, nonrepudiation, availability
 - Reporting compliance with local legislation
 - Backup and restoration
 - Timestamp
 - Logical access management (minimum 2 factors access mechanism)
 - General computer controls
 - Unique account session
 - Incident response plan
 - Change management

Other - Sarbanes- Oxely Act

Is a United States federal law that set new or expanded requirements for all U.S. public company boards, management and public accounting firms.

The bill, which contains eleven sections, was enacted as a reaction to a number of major corporate and accounting scandals

- Section 302: Disclosure controls
- Section 303: Improper influence on conduct of audits
- Section 401: Disclosures in periodic reports (Off-balance sheet items)
- **Section 404: Assessment of internal control**
- Section 802: Criminal penalties for influencing US Agency investigation/proper administration
- 806: Civil action to protect against retaliation in fraud cases
- Section 906: Criminal Penalties for CEO/CFO financial statement certification
- Section 1107: Criminal penalties for retaliation against whistleblowers

Other – NIST

The **National Institute of Standards and Technology (NIST)** is a physical sciences laboratory, and a non-regulatory agency of the United States Department of Commerce. Its mission is to promote innovation and industrial competitiveness. NIST's activities are organized into laboratory programs that include nanoscale science and technology, engineering, information technology, neutron research, material measurement, and physical measurement.

NIST 800-53 is a publication that recommends security **controls** for federal information systems and organizations and documents security **controls** for all federal information systems, except those designed for national security.

Those safeguarding measures include **security and privacy controls** to protect the critical and essential operations and assets of organizations and the personal **privacy** of individuals.

These controls are the operational, technical, and management safeguards used by information systems to maintain the integrity, confidentiality, and security of federal information systems

The **NIST SP 800-53 security control families** are: AccessControl. Audit and Accountability. Awareness and Training

Other — GDPR

The General Data Protection Regulation 2016/679 is a regulation in EU law on data protection and privacy for all individual citizens of the European Union and the European Economic Area. It also addresses the transfer of personal data outside the EU and EEA areas.

The GDPR aims primarily to give control to individuals over their personal data and to simplify the regulatory environment for international business by unifying the regulation within the EU. Superseding the Data Protection Directive 95/46/EC, the regulation contains provisions and requirements related to the processing of personal data of individuals (formally called *data subjects* in the GDPR) inside the EEA, and applies to any enterprise established in the EEA or—regardless of its location and the data subjects' citizenship—that is processing the personal information of data subjects inside the EEA.

Controllers of personal data must put in place *appropriate technical and organizational measures* to implement the data protection principles. Business processes that handle personal data must be designed and built with consideration of the principles and provide safeguards to protect data, and use the highest-possible privacy settings by default, so that the datasets are not publicly available without explicit, informed consent, and cannot be used to identify a subject without additional information.

No personal data may be processed unless this processing is done under a lawful basis specified by the regulation, or unless the data controller or processor has received an unambiguous and individualized affirmation of consent from the data subject. The data subject has the right to revoke this consent at any time.

Other – NIS Directive

- The **NIS Directive** is the first piece of EU-wide **legislation** on cybersecurity. It provides legal measures to boost the overall level of cybersecurity in the EU.
- On July 6, 2016, the European Parliament set into policy the Directive on Security of Network and Information Systems (the NIS Directive).

The directive **went into effect in August 2016**, and all member states of the European Union were given **21 months** to incorporate the directive's regulations into their own national laws. The aim of the NIS Directive is to create an overall higher level of cybersecurity in the EU. The directive significantly affects digital service providers (DSPs) and operators of essential services (OESs). Operators of essential services include any organizations whose operations would be greatly affected in the case of a security breach if they engage in critical societal or economic activities.

- On the 16 January 2023, the EU Parliament and Council adopted the 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS Directive). This new Directive aims to extend the scope of obligations on entities required to take measures to increase their cybersecurity capabilities. The Directive also aims to harmonise the EU approach to incident notifications, security requirements, supervisory measures and information sharing.
- Dec 2024 – Romanian legislation aligned with NIS2 was approved and published.

Law 155/2024

[Ordonanța de urgență nr. 155/2024 privind instituirea unui cadru pentru securitatea cibernetică a rețelelor și sistemelor informatice din spațiul cibernetic național civil - Lege5.ro](#)
[oug-privind-transpunerea-directivei-nis-2](#)
[Guvernul României](#)

Case studies



January 22nd, 2025

06:30 – 08:00 Case studies

08:00 – 08:15 Break

08:15 – 09:30 Quiz & clarifications

Un test de incendiu, cu efecte peste așteptări, a „ars” sâmbătă sistemul informatic al ING-ului. Clienții nu au putut să scoată bani sau să facă operațiuni. Comisioanele de retragere de la alte bănci vor fi returnate. Umorul clienților, de neprețuit: „ING ține la economiile oamenilor, altfel câți bani am fi cheltuit sâmbăta asta dacă am fi putut?”



Problema de securitate gravă a Windows. Chiar și NSA vrea să faci update



Marriott News Center

Marriott International Update on Starwood Reservation Database Security Incident

Situație critică pentru o bancă din top 10. ING: "ATM-urile, POS-urile, cardurile și Home Banking-ul nu funcționează"



Snowden was a "genius among geniuses" who created a widely implemented backup system for the NSA and often pointed out security flaws to the agency. The former colleague said Snowden was given **full administrator privileges with virtually unlimited access to NSA data**. Snowden was offered a position on the NSA's elite team of hackers, Tailored Access Operations, but turned it down to join Booz Allen.^[79] An anonymous source later said that Booz Allen's hiring screeners found

A laptop he kept in his car at home, which had an internet browser installed on the laptop, and one of these browsers could only be loaded via external hard drive - this was the browser he used to arrange affairs. So Michael was "irritated and surprised" to realise, that Monday morning, that his elaborate precautions had been pointless. He tried to work out ways in which he would be exposed if the hackers went through with their threat to release Ashley Madison's customer database.



Equifax failed to patch security vulnerability in March -- testimony

By Reuters Staff

1 MIN READ



WASHINGTON, Oct 2 (Reuters) - Equifax Inc failed to patch a software security vulnerability after being alerted in March by the U.S. Homeland Security Department to the issue that led to hackers obtaining personal information from over 140 million Americans, the company's former chief executive will tell Congress in written testimony made public Monday.

"It appears that the breach occurred because of both human error and technology failures," said former CEO Richard Smith, who apologized for the breach before his appearance before a U.S. House committee on Tuesday and said the company is taking a number of steps to better protect personal data.

Would an audit have been useful for this?

NO

CASE STUDIES

1

Crowdstrike security incident

[CrowdStrike, Microsoft Outage: Is Tech Too Vulnerable? - Georgetown University](#)

2

Solarwinds security incident

[SolarWinds hack explained: Everything you need to know](#)

3

Marriott case

[Marriott data breach FAQ: How did it happen and what was the impact? | CSO Online](#)

4

Snowden's Leaks

https://en.wikipedia.org/wiki/Edward_Snowden

[House Intelligence Committee Releases Snowden Report Summary | Lawfare](#)

5

Ashley Madison data breach

[Ashley Madison data breach – Wikipedia](#)

[PIPEDA Report of Findings #2016-005: Joint investigation of Ashley Madison by the Privacy Commissioner of Canada and the Australian Privacy Commissioner/Acting Australian Information Commissioner - Office of the Privacy Commissioner of Canada](#)

Resources I

- [IT Audit Framework \(ITAF™\): A Professional Practices Framework for IT Audit, 4th Edition](#)
- [An ITAF Approach to IT Audit Advisory Services](#)
- [ITAF™ Companion Performance Guidelines 2208](#)
- CISA Review Manual 26th Edition (ISACA 2016)
- [Ordin-553-2019.pdf](#) - auditul sistemelor de plata la distanta (Internet banking)
- [LEGE 135 15/05/2007 - Portal Legislativ](#) – legea privind arhivarea documentelor in forma electronica
- [Ordinul Ministrului MCSI nr. 493 / 15.06.2009 privind normele tehnice și metodologice pentru aplicarea Legii nr. 135/2007 privind arhivarea documentelor în formă electronica](#)
- [Norma nr. 4/2018 privind gestionarea riscurilor operaționale generate de sistemele informatice utilizate de entitățile autorizate/ avizate/ înregistrate/ reglementate și/sau supravegheate de către Autoritatea de Supraveghere Financiară](#)
- [ISO/IEC 27000 family](#)

Resources II

- [ISO 19011:2018 - Guidelines For Auditing Management Systems](#) (SR EN ISO 19011:2018, Linii directoare pentru auditarea sistemelor de management)
- [ISO 31000 – Risk Management](#)
- [ISO 38500 - International standard for Corporate governance of information technology](#)
- [Sarbanes Oxley Act](#)
- [NIST papers](#)
- [NIS regulation](#)
- [GDPR regulation](#)
- [COBIT 5](#)
- [www.ibm.com/reports/data-breach](#)
- [www.linkedin.com/pulse/evolution-audit-skills-2024-beyond-5bmde/](#)
- [www2.deloitte.com/us/en/pages/advisory/articles/the-future-of-IT-internal-audit.html](#)
- [kpmg.com/ch/en/insights/reporting/future-of-audit.html](#)
- [www.linkedin.com/pulse/future-auditing-trends-technologies-challenges-jonathan-prewitt-repjc/](#)

Resources III

- <https://www.csoononline.com/article/3519908/the-cia-triad-definition-components-and-examples.html>
- <https://www.isaca.org/resources/isaca-journal/past-issues/2011/data-integrity-information-security-s-poor-relation>
- [Incident Response | CSRC](#)
- [OWASP Mobile Application Security](#)
- [Cloud Controls Matrix and CAIQ v4 | CSA](#)
- [WSTG - Latest | OWASP Foundation](#)
- [NIST Privacy Framework and Cybersecurity Framework to NIST Special Publication 800-53, Revision 5 Crosswalk | NIST](#)
- [GDPR Crosswalk by Enterprivacy Consulting Group | NIST](#)
- [SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations | CSRC](#)
- [Search | CSRC](#)
- [CIS Benchmarks](#)
- [CIS Controls](#)

Q&A

ISACA materials used for this course have been mentioned in the “Resource” slide. Usage of the slides including such information as well any additional ISACA documentation provided to the students as study materials should be limited to academic purposes, as the entire documentation of ISACA is under copyright and intellectual property rules.